
GDPR

Plain-Language Obligation and Audit Guide

Regulation (EU) 2016/679

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

The seven principles of Article 5.
Scope, roles, lawfulness, and the conditions for consent.
All data subject rights, Articles 12 to 23.
Controller and processor obligations, Articles 24 to 43.
International transfers, remedies and penalties,
and the specific processing situations of Chapter IX.

Before You Use This Document

This is a companion guide, not a copy of the standard.

Unlike the ISO standards covered by the companion guides, Regulation (EU) 2016/679 is published law and freely available in every official language of the Union. This guide still does not reproduce it: every obligation here is described in original wording with the article number as a pointer, because the point is to make the obligations usable rather than to restate them.

Read the Regulation itself for anything consequential. This guide is not legal advice. The GDPR is a legal instrument whose application frequently turns on facts, on Member State implementing law, and on supervisory authority and court interpretation that continues to develop. Where this guide and the Regulation appear to differ, the Regulation governs.

Two areas in particular move: the validity of transfer mechanisms under Chapter V, and the interpretation of Article 22 as it applies to AI systems. Check the current position on both rather than relying on this guide alone.

What this guide does

It takes each obligation in the Regulation and answers six questions about it, in the same order every time:

1. **What the obligation requires.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning. Here it marks the administrative fine tier under Article 83, which is factual rather than a judgment about importance:

Orange, marked 4%

Breach attracts the higher tier under Article 83(5): up to EUR 20 million or four per cent of total worldwide annual turnover, whichever is higher. This covers the basic principles and conditions for consent (Articles 5, 6, 7 and 9), all data subject rights (Articles 12 to 22), all transfer provisions (Articles 44 to 49), and obligations under Member State law adopted under Chapter IX.

Orange, marked 2%

Breach attracts the standard tier under Article 83(4): up to EUR 10 million or two per cent. This covers the controller and processor obligations in Articles 25 to 39, together with Articles 8, 11, 42 and 43.

Blue

Provisions that define, enable, or provide remedies but carry no administrative fine of their own: scope and role determination, Article 24, the restriction power in Article 23, and the remedy and penalty articles themselves.

Blue does not mean unimportant, and the tiering is not a ranking of severity. Article 30, the record of processing activities, sits in the lower tier and is the first document a supervisory authority will ask for; getting the controller-processor determination wrong is blue and is how organizations end up in breach of everything in orange. But when a programme has to be sequenced against limited capacity, penalty tier is a defensible way to sequence it.

One consequence of the tiering is worth noting up front: data subject rights sit in the higher tier as a block. Rights fulfilment is often treated as an operational service matter and resourced accordingly, while carrying the same maximum exposure as a breach of the fundamental principles.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The tiering is stated in Article 83 rather than being a judgment of this guide; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

How this guide is organized

The first chapter covers the seven principles of Article 5, which are the substantive core of the Regulation. Almost every finding elsewhere traces back to one of them, and reading them first makes the rest cohere. The chapters that follow work through scope and roles, lawfulness, data subject rights, controller and processor obligations, international transfers, remedies and penalties, and the specific processing situations of Chapter IX.

Coverage is the substantive obligations that fall on a controller or processor. The chapters governing supervisory authority structure, cooperation and consistency between authorities, and the delegated and implementing act machinery are outside scope, since they do not create auditable obligations for a controller.

Five things that catch people out

Pseudonymised data is personal data. So is data you hold under a hashed or tokenised identifier, and so is anything re-identifiable through linkage with other data you hold. The identifiability test is relative, not absolute. Treating such a dataset as out of scope removes it from every protection in the Regulation at once, which makes this the highest-leverage error available.

Retention is where the evidence already exists. Find the oldest record in each significant system and compare it against the organization's own retention schedule. This single test takes very little time and produces a finding in most environments, because deletion is routinely scheduled and never executed.

The 72-hour breach clock runs from awareness, not from conclusion. Awareness arises when there is a reasonable degree of certainty that a breach has occurred, not when the investigation finishes or when the incident is formally declared. Establish the point of awareness independently; the gap between discovery and declaration is where the deadline is usually lost.

Human review does not take a decision outside Article 22. If the reviewer confirms the automated output without meaningful engagement, the decision is solely automated in substance whatever the process diagram says. Ask for the override rate against decision volume and the time allocated per decision. Those two numbers settle it.

Rights fulfilment usually stops at the primary system. Personal data sits in backups, logs, analytics stores, non-production copies, and email. Take a sampled request, list the systems actually searched or actioned, and compare against the full processing inventory. The gap is the finding, and it applies equally to access, rectification, erasure, and objection.

Three definitions you need before anything else

Controller and processor

A controller determines the purposes and means of processing; a processor acts on its behalf. The distinction follows the factual reality of who decides, not the label in the contract. A supplier contracted as a processor that exercises real discretion over how or why data is used is a controller, with direct obligations neither party will have met.

Legal basis

One of the six grounds in Article 6, required for every processing activity, plus an Article 9 condition where special category data is involved. The choice is not a formality: it determines which rights apply. Consent brings withdrawal and portability, legitimate interests brings the right to object, and contract brings portability.

Special category data

The Article 9 categories, plus anything *revealing* them. That captures inference and proxies, not only declared fields, so free-text notes, images, and derived attributes routinely contain special category data the organization does not know it holds and processes with no Article 9 condition at all.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to "do it better." Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Principles: Article 5	1
Art. 5(1)(a) Lawfulness, fairness and transparency	2
Art. 5(1)(b) Purpose limitation	3
Art. 5(1)(c) Data minimisation	4
Art. 5(1)(d) Accuracy	5
Art. 5(1)(e) Storage limitation	6
Art. 5(1)(f) Integrity and confidentiality	7
Art. 5(2) Accountability	8
2 Scope, Roles, and Key Definitions	9
Art. 2 Material scope: what processing is covered	10
Art. 3 Territorial scope: establishment and targeting	11
Art. 4 Key definitions: personal data, processing, pseudonymisation	12
Art. 4(7)/(8) Controller and processor roles	13
3 Lawfulness of Processing	14
Art. 6 Lawfulness of processing: the six legal bases	15
Art. 6(4) Further processing and the compatibility test	16
Art. 7 Conditions for consent	17
Art. 8 Child's consent for information society services	18
Art. 9 Special categories of personal data	19
Art. 10 Personal data relating to criminal convictions and offences	20
Art. 11 Processing not requiring identification	21
4 Rights of the Data Subject	22
Art. 12 Transparent information and modalities for exercising rights	23
Art. 13 Information where data is collected from the data subject	24
Art. 14 Information where data is not obtained from the data subject	25
Art. 15 Right of access	26
Art. 16 Right to rectification	27
Art. 17 Right to erasure	28
Art. 18 Right to restriction of processing	29
Art. 19 Notification obligation regarding rectification, erasure, or restriction	30
Art. 20 Right to data portability	31
Art. 21 Right to object	32
Art. 22 Automated individual decision-making, including profiling	33
Art. 23 Restrictions under Union or Member State law	34
5 Controller and Processor Obligations	35

Art. 24	Responsibility of the controller	37
Art. 25	Data protection by design and by default	38
Art. 26	Joint controllers	39
Art. 27	Representatives of controllers or processors not established in the Union	40
Art. 28	Processor obligations and the processing contract	41
Art. 29	Processing under the authority of the controller or processor	42
Art. 30	Records of processing activities	43
Art. 31	Cooperation with the supervisory authority	44
Art. 32	Security of processing	45
Art. 33	Notification of a personal data breach to the supervisory authority	46
Art. 34	Communication of a personal data breach to the data subject	47
Art. 35	Data protection impact assessment	48
Art. 36	Prior consultation with the supervisory authority	49
Art. 37	Designation of the data protection officer	50
Art. 38	Position of the data protection officer	51
Art. 39	Tasks of the data protection officer	52
Art. 40-41	Codes of conduct and monitoring	53
Art. 42-43	Certification and certification bodies	54
6	International Transfers	55
Art. 44	General principle for transfers	56
Art. 45	Transfers on the basis of an adequacy decision	57
Art. 46	Transfers subject to appropriate safeguards	58
Art. 47	Binding corporate rules	59
Art. 48	Transfers or disclosures not authorised by Union law	60
Art. 49	Derogations for specific situations	61
7	Remedies, Liability, and Penalties	62
Art. 77-79	Complaints and judicial remedies	63
Art. 82	Right to compensation and liability	64
Art. 83	General conditions for imposing administrative fines	65
Art. 84	Penalties under Member State law	66
8	Specific Processing Situations	67
Art. 85	Processing and freedom of expression and information	68
Art. 87	Processing of national identification numbers	69
Art. 88	Processing in the context of employment	70
Art. 89	Safeguards for archiving, research, and statistical purposes	71
	Glossary	72
	Index of Terms and Concepts	75

CHAPTER 1

The Principles: Article 5

The seven principles of Article 5. Everything else in the Regulation elaborates, qualifies, or enforces these, and almost every finding elsewhere in this guide traces back to one of them. All seven sit in the higher fine tier.

Two are worth approaching first because they produce findings quickly. Storage limitation at Article 5(1)(e) is the most commonly breached and the easiest to evidence: find the oldest record in each significant system and compare it against the organization's own retention schedule. Data minimisation at Article 5(1)(c) is tested field by field rather than dataset by dataset, and fields collected but never used are unambiguous findings requiring no judgment about necessity.

Article 5(2) accountability is different in kind from the other six. It requires not compliance but demonstrable compliance, which converts every other principle into an evidence requirement and reverses the usual burden of proof. Where an organization is substantively compliant but cannot show it, record that as an accountability finding in its own right, because the remedy differs from fixing the underlying principle.

Quick reference: the seven principles

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Art. 5(1)(a) 4%	Lawfulness, fairness and transparency	Legal basis determination per processing activity, with date
Art. 5(1)(b) 4%	Purpose limitation	Stated purposes per processing activity
Art. 5(1)(c) 4%	Data minimisation	Field-level inventory per processing activity
Art. 5(1)(d) 4%	Accuracy	Accuracy maintenance mechanisms per activity
Art. 5(1)(e) 4%	Storage limitation	Retention schedule with periods per data category
Art. 5(1)(f) 4%	Integrity and confidentiality	Technical and organisational measures with risk linkage
Art. 5(2) 4%	Accountability	Documented evidence per principle

Art. 5(1)(a) Lawfulness, fairness and transparency**WHAT THE ARTICLE REQUIRES**

Personal data must be processed lawfully, fairly, and in a transparent manner in relation to the data subject. Lawfulness requires a valid legal basis under Article 6, and Article 9 conditions where special category data is involved. Fairness concerns whether the processing is within what the data subject could reasonably expect and does not exploit an imbalance. Transparency requires that people can find out what is happening to their data, in accessible terms.

WHY IT EXISTS

These three are grouped because they fail together. Processing can have a valid legal basis and still be unfair, or be lawful and fair but concealed. Fairness is the element with the least precise definition and the widest reach: it is where regulators land on processing that is technically permitted but would surprise or disadvantage the people subject to it, including dark patterns and undisclosed inference.

HOW TO AUDIT IT

1. For each processing activity, identify the legal basis and check it was determined before processing started rather than reconstructed afterwards.
2. Test fairness by comparing what the organization actually does against what a data subject reading the privacy notice would expect.
3. Check whether inferred and derived data is disclosed, since inference is a common gap between the notice and the reality.
4. Verify transparency information is accessible in practice, not merely published.

EVIDENCE TO COLLECT

- Legal basis determination per processing activity, with date
- Privacy notices as actually presented to data subjects
- Record of inferred or derived data and its disclosure

HOW TO DOCUMENT IT

Record the legal basis per activity and whether it predates the processing. Note any processing that a data subject would not anticipate from the notice, since that gap is the fairness finding and it is the one most likely to be defended rather than fixed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization derives attributes about individuals that are not disclosed in any privacy notice, so the processing goes beyond what data subjects are told and can reasonably expect.

Art. 5(1)(b) Purpose limitation

WHAT THE ARTICLE REQUIRES

Personal data must be collected for specified, explicit, and legitimate purposes and not further processed in a manner incompatible with those purposes. Further processing for archiving in the public interest, scientific or historical research, or statistical purposes is not considered incompatible, subject to the Article 89 safeguards.

WHY IT EXISTS

Purpose limitation is the constraint that prevents data collected for one reason becoming a general-purpose organizational asset. It is the principle most eroded by ordinary business pressure: data already held is cheap to reuse, and each individual reuse seems reasonable while the aggregate drift is substantial. Vague purpose statements defeat the principle at the outset, which is why purposes must be specified and explicit rather than broad.

HOW TO AUDIT IT

1. Obtain stated purposes and assess specificity, since a purpose such as improving our services permits almost anything.
2. Compare actual processing against stated purposes and identify uses not covered.
3. For further processing, check whether a compatibility assessment was performed under Article 6(4).
4. Look at analytics, model training, and secondary internal uses specifically, since these are where drift concentrates.

EVIDENCE TO COLLECT

- Stated purposes per processing activity
- Actual processing evidence for comparison
- Article 6(4) compatibility assessments

HOW TO DOCUMENT IT

Record purposes as stated against processing as observed, listing uses with no matching purpose. Note whether compatibility assessments exist for further processing, since their absence means the compatibility judgment was never made.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data collected for service delivery is used to train models and generate analytics without any documented compatibility assessment, so the processing has expanded beyond the purposes for which the data was obtained.

Art. 5(1)(c) Data minimisation

WHAT THE ARTICLE REQUIRES

Personal data must be adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed. All three tests apply: data that is insufficient for the purpose is as much a failure as data that exceeds it.

WHY IT EXISTS

Minimisation is the principle with the greatest practical effect on breach severity, because data not held cannot be exposed. It runs directly against the default engineering instinct to collect everything in case it proves useful later, and it is tested field by field: the question is not whether the dataset is reasonable overall but whether each element is necessary for the stated purpose.

HOW TO AUDIT IT

1. Take a processing activity and test necessity field by field against the stated purpose.
2. Identify fields collected but never used, which are the clearest minimisation failures.
3. Check whether the full dataset is needed for each purpose or whether some purposes need only a subset.
4. Examine free-text fields, which routinely accumulate far more than intended.

EVIDENCE TO COLLECT

- Field-level inventory per processing activity
- Usage evidence per field
- Necessity justification for sensitive or high-risk fields

HOW TO DOCUMENT IT

List fields collected and not used, since these are unambiguous findings requiring no judgment about necessity. Note free-text fields and what they actually contain, as against what they were intended for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of personal data fields are collected and retained without being used for any stated purpose, and free-text fields contain special category data the organization did not intend to hold.

Art. 5(1)(d) Accuracy

WHAT THE ARTICLE REQUIRES

Personal data must be accurate and, where necessary, kept up to date. Every reasonable step must be taken to ensure that inaccurate data is erased or rectified without delay, having regard to the purposes for which it is processed. The standard is tied to purpose: the accuracy required depends on what the data is used for.

WHY IT EXISTS

Inaccurate data produces wrong decisions about real people, and the harm scales with the consequence of the decision. This principle is where inference and derived data create the most exposure, because an inferred attribute may be wrong in a way the individual cannot see or challenge, yet it drives outcomes affecting them.

HOW TO AUDIT IT

1. Check what mechanisms maintain accuracy and whether they are proportionate to the consequences of error.
2. Examine inferred and derived data specifically, since these are frequently unverified and unchallengeable.
3. Verify rectification actually propagates to downstream systems and copies rather than correcting one record.
4. Test the interaction with Article 16 rectification requests.

EVIDENCE TO COLLECT

- Accuracy maintenance mechanisms per activity
- Rectification propagation evidence across systems
- Accuracy approach for inferred data

HOW TO DOCUMENT IT

Record whether rectification propagates to all copies and downstream systems, since correcting the primary record while stale copies persist means the inaccurate data continues driving decisions.

EXECUTIVE SUMMARY TREATMENT

Suggested language: rectifications are applied to the primary record only, and a stated number of downstream systems retain the uncorrected data, so decisions continue to be made on information the organization knows to be wrong.

Art. 5(1)(e) Storage limitation

WHAT THE ARTICLE REQUIRES

Personal data must be kept in a form permitting identification of data subjects for no longer than is necessary for the purposes for which it is processed. Longer storage is permitted for archiving in the public interest, scientific or historical research, or statistical purposes, subject to the Article 89 safeguards.

WHY IT EXISTS

Storage limitation is the most commonly breached principle and the easiest to evidence, because the failure is a matter of record. Retention schedules routinely exist on paper while deletion never runs, and the result is an accumulating store of data whose only function is to enlarge the consequences of a breach.

HOW TO AUDIT IT

1. Obtain the retention schedule, then test it against reality by finding the oldest record in each significant system.
2. Check whether deletion is automated and actually executes, or is manual and therefore aspirational.
3. Examine backups, archives, logs, and non-production copies, which are where data outlives its schedule.
4. Verify anonymisation claimed as an alternative to deletion is irreversible.

EVIDENCE TO COLLECT

- Retention schedule with periods per data category
- Oldest-record evidence per system
- Deletion job configuration and execution logs
- Backup and archive retention

HOW TO DOCUMENT IT

Report the oldest record found in each system against its scheduled retention period. This single test is the most efficient in the whole guide and it consistently produces findings.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is retained well beyond the periods in the organization's own retention schedule, the oldest by a stated number of years, because scheduled deletion has never been executed in production.

Art. 5(1)(f) Integrity and confidentiality**WHAT THE ARTICLE REQUIRES**

Personal data must be processed in a manner ensuring appropriate security, including protection against unauthorised or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organisational measures. This is the principle Article 32 elaborates.

WHY IT EXISTS

This principle covers both malicious and accidental harm, and the accidental limb is frequently overlooked: loss and destruction of data are breaches as much as unauthorised access. It also covers unauthorised processing by people who legitimately hold access, which is why access control alone does not discharge it.

HOW TO AUDIT IT

1. Assess security measures against the risk of the specific processing rather than against a generic standard.
2. Check protection against accidental loss and destruction, not only against unauthorised access.
3. Examine internal misuse risk, since authorised users processing data for unauthorised reasons is within scope.
4. Verify measures cover all copies and environments, including non-production.

EVIDENCE TO COLLECT

- Technical and organisational measures with risk linkage
- Backup and recovery evidence
- Internal access monitoring
- Non-production environment protection

HOW TO DOCUMENT IT

Record whether non-production environments hold real personal data and what protects them, since these are consistently less protected than production while holding the same data.

EXECUTIVE SUMMARY TREATMENT

Suggested language: non-production environments contain live personal data with materially weaker access controls than production, so the organization's real exposure is set by its least protected environment.

Art. 5(2) Accountability

WHAT THE ARTICLE REQUIRES

The controller is responsible for, and must be able to demonstrate compliance with, the principles in Article 5(1). This is the accountability principle: compliance is not enough, it must be demonstrable.

WHY IT EXISTS

Accountability is what converts every other principle into an evidence requirement, and it reverses the usual burden: the controller must be able to show compliance rather than a regulator having to show its absence. An organization that is compliant but cannot demonstrate it is in breach of Article 5(2) regardless of the underlying position.

HOW TO AUDIT IT

1. For each principle, ask what evidence exists to demonstrate compliance, and treat its absence as a distinct finding.
2. Check whether decisions and their reasoning are recorded, since undocumented judgments cannot be demonstrated.
3. Verify the evidence would satisfy a regulator rather than only an internal reviewer.
4. Look for compliance resting on individual knowledge rather than record.

EVIDENCE TO COLLECT

- Documented evidence per principle
- Decision records with reasoning
- Governance and review records

HOW TO DOCUMENT IT

Where the organization is compliant but cannot demonstrate it, record this as an accountability finding in its own right, separate from the underlying principle. This distinction matters because the remedy is different.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot demonstrate compliance with the data protection principles, as decisions on legal basis, retention, and necessity rest on individual knowledge rather than documented reasoning, which is itself a breach of the accountability principle.

Scope, Roles, and Key Definitions

Four entries covering the questions that determine whether and how the Regulation applies at all. Blue throughout, because these provisions define rather than oblige, but an error here invalidates everything downstream.

Two determinations carry disproportionate weight. The identifiability test in Article 4 is relative, not absolute: data is personal if the controller or anyone else can reasonably identify the individual using all means reasonably likely to be used. Pseudonymised data is personal data. An incorrect classification here removes a dataset from every protection in the Regulation simultaneously, which makes it the highest-leverage error available.

The controller-processor distinction is the other. It follows the factual reality of who determines purposes and means, not the label in the contract, so a supplier described as a processor may in fact be a controller with direct obligations neither party has met. Test the facts against the label for every significant relationship.

Quick reference: Scope and Roles

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Art. 2	Material scope: what processing is covered	Scope determination with rationale
Art. 3	Territorial scope: establishment and targeting	Territorial scope assessment
Art. 4	Key definitions: personal data, processing, pseudonymisation	Data classification decisions with reasoning
Art. 4(7)/(8)	Controller and processor roles	Role determinations per relationship

Art. 2 Material scope: what processing is covered

WHAT THE ARTICLE REQUIRES

The Regulation applies to the processing of personal data wholly or partly by automated means, and to non-automated processing of personal data forming part of a filing system or intended to do so. It does not apply to processing in the course of a purely personal or household activity, nor to processing by competent authorities for law enforcement purposes, which is covered by separate legislation.

WHY IT EXISTS

Scope determines whether the rest applies at all, and the common error is assuming that unstructured or paper-based data falls outside it. Structured paper files are in scope, and the automated limb captures essentially all digital processing, including data held only in email or spreadsheets.

HOW TO AUDIT IT

1. Establish what processing the organization performs and confirm the scope determination covers all of it.
2. Check that structured paper records and unstructured digital holdings were considered, not only formal systems.
3. Verify any claimed exclusion is genuinely available rather than assumed.

EVIDENCE TO COLLECT

- Scope determination with rationale
- Processing inventory covering digital and paper

HOW TO DOCUMENT IT

Record processing the organization treats as out of scope and the basis for that treatment, since incorrect scope exclusions invalidate everything downstream.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data held in shared drives and email is treated as outside the Regulation's scope, which is incorrect, so a significant volume of processing is subject to no data protection controls.

Art. 3 Territorial scope: establishment and targeting

WHAT THE ARTICLE REQUIRES

The Regulation applies to processing in the context of the activities of an establishment in the Union, regardless of where processing occurs. It also applies to controllers or processors outside the Union where processing relates to offering goods or services to data subjects in the Union, or to monitoring their behaviour within the Union.

WHY IT EXISTS

The targeting limb extends the Regulation well beyond EU-based organizations, and the monitoring limb is broader than most organizations expect: behavioural tracking of people in the Union brings a non-EU organization within scope without any deliberate offering of services. Getting this wrong means an organization discovers its obligations through an enforcement action.

HOW TO AUDIT IT

1. Determine whether the organization has an EU establishment and whether processing relates to its activities.
2. For non-EU processing, assess the offering and monitoring limbs against actual activity.
3. Check whether website analytics, advertising technology, or app telemetry constitutes monitoring of EU data subjects.
4. Verify an Article 27 representative is appointed where required.

EVIDENCE TO COLLECT

- Territorial scope assessment
- Evidence on targeting and monitoring of EU data subjects
- Article 27 representative appointment where applicable

HOW TO DOCUMENT IT

Record the basis for the territorial scope conclusion, and note whether behavioural monitoring of EU data subjects was assessed, since this limb is the one most often missed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization monitors the behaviour of individuals in the Union through website tracking without having assessed territorial scope or appointed a representative under Article 27.

Art. 4 Key definitions: personal data, processing, pseudonymisation**WHAT THE ARTICLE REQUIRES**

Personal data is any information relating to an identified or identifiable natural person, where identifiability may arise directly or indirectly, including by reference to an identifier or to factors specific to that person. Processing means virtually any operation performed on personal data. Pseudonymised data remains personal data; only genuinely anonymous data falls outside the Regulation.

WHY IT EXISTS

The identifiability test is the single most consequential definition, and it is relative rather than absolute: data is personal if the controller or anyone else can reasonably identify the individual, taking account of all means reasonably likely to be used. Organizations routinely treat pseudonymised or hashed data as out of scope, which is wrong and removes it from all protection.

HOW TO AUDIT IT

1. Test data the organization treats as non-personal against the identifiability standard, considering all reasonably available means.
2. Check whether pseudonymised data is correctly treated as personal data.
3. Examine claimed anonymisation for reversibility, including through linkage with other held data.
4. Verify unique identifiers, device identifiers, and IP addresses are treated as personal data where they are.

EVIDENCE TO COLLECT

- Data classification decisions with reasoning
- Anonymisation methodology and re-identification testing
- Identifier handling

HOW TO DOCUMENT IT

Record datasets treated as non-personal and test the basis, since an incorrect classification removes data from every protection in the Regulation simultaneously.

EXECUTIVE SUMMARY TREATMENT

Suggested language: datasets treated as anonymous remain re-identifiable through linkage with other data the organization holds, so they are personal data receiving none of the required protections.

Art. 4(7)/(8) Controller and processor roles**WHAT THE ARTICLE REQUIRES**

A controller determines the purposes and means of processing; a processor processes on behalf of a controller. The distinction follows the factual reality of who decides, not what the contract says. Joint controllers under Article 26 jointly determine purposes and means and must arrange their respective responsibilities transparently.

WHY IT EXISTS

Role determines which obligations apply, and misclassification is common in both directions. A supplier described as a processor in the contract may in fact determine purposes, making it a controller with direct obligations it has not met. The determination is factual, so a contractual label does not fix an incorrect classification.

HOW TO AUDIT IT

1. For each significant relationship, test who actually determines purposes and means against the contractual label.
2. Look for suppliers exercising discretion over how or why data is used, which indicates controller status.
3. Check joint controller arrangements exist where purposes are jointly determined.
4. Verify obligations follow the correct role rather than the assumed one.

EVIDENCE TO COLLECT

- Role determinations per relationship
- Contracts for comparison against factual reality
- Joint controller arrangements

HOW TO DOCUMENT IT

Record relationships where the factual role differs from the contractual label, since the obligations follow the facts and the organization will have applied the wrong set.

EXECUTIVE SUMMARY TREATMENT

Suggested language: suppliers contracted as processors exercise independent discretion over the use of personal data, making them controllers, so neither party has met the obligations that actually apply to the relationship.

CHAPTER 3

Lawfulness of Processing

Seven entries on the conditions that make processing lawful. Mostly 4

The legal basis is not a formality: it determines which rights apply. Consent brings withdrawal and portability; legitimate interests brings the right to object; contract brings portability. A basis chosen loosely leaves the organization unable to answer rights requests coherently, so the test is not only whether a basis is recorded but whether the rights it triggers are operationally supported.

Article 6(4) is the most consistently skipped provision in this chapter. Any secondary use requires a compatibility assessment against the listed factors, and organizations extend processing into analytics, product development, and model training without performing it. Article 9 carries the other recurring finding: data revealing a special category is itself special category data, which captures inference and proxies, not only declared fields. Free-text and image data routinely contain special category data the organization does not know it holds.

Quick reference: Lawfulness

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Art. 6^{4%}	Lawfulness of processing: the six legal bases	Legal basis register with dates
Art. 6(4)^{4%}	Further processing and the compatibility test	Compatibility assessments per secondary use
Art. 7^{4%}	Conditions for consent	Consent interfaces as presented
Art. 8^{2%}	Child's consent for information society services	Age verification measures
Art. 9^{4%}	Special categories of personal data	Special category data inventory including inferred data
Art. 10	Personal data relating to criminal convictions and offences	Criminal offence data inventory
Art. 11^{2%}	Processing not requiring identification	Article 11 determinations

Art. 6 Lawfulness of processing: the six legal bases

WHAT THE ARTICLE REQUIRES

Processing is lawful only if at least one basis applies: consent, necessity for a contract, compliance with a legal obligation, protection of vital interests, performance of a task in the public interest or exercise of official authority, or legitimate interests pursued by the controller or a third party, except where overridden by the data subject's interests and rights. The public interest and legal obligation bases must have a foundation in Union or Member State law. Legitimate interests are unavailable to public authorities in the performance of their tasks.

WHY IT EXISTS

The legal basis determines which data subject rights apply, so choosing it is not a formality: consent brings withdrawal and portability, legitimate interests brings the right to object, and contract brings portability. A basis selected loosely or changed retrospectively leaves the organization unable to answer rights requests coherently.

HOW TO AUDIT IT

1. Confirm a basis is identified for every processing activity, recorded before processing began.
2. Check the basis is appropriate: consent is not valid where there is an imbalance of power, and contract necessity means necessary rather than convenient.
3. For legitimate interests, obtain the balancing assessment and check it genuinely weighs the data subject's interests.
4. Verify the rights the chosen basis triggers are actually supported operationally.

EVIDENCE TO COLLECT

- Legal basis register with dates
- Legitimate interests assessments
- Evidence that basis-dependent rights are supported

HOW TO DOCUMENT IT

Record the basis per activity and whether the corresponding rights are operationally supported, since a basis claimed without supporting its rights is not really the basis being relied on.

EXECUTIVE SUMMARY TREATMENT

Suggested language: processing relies on legitimate interests with no documented balancing assessment, and the right to object that this basis triggers is not operationally supported.

Art. 6(4) Further processing and the compatibility test**WHAT THE ARTICLE REQUIRES**

Where processing for a purpose other than that for which data was collected is not based on consent or on Union or Member State law, the controller must ascertain whether the new purpose is compatible with the original, taking account of any link between the purposes, the context of collection, the nature of the data, the possible consequences for data subjects, and the existence of appropriate safeguards.

WHY IT EXISTS

This is the operative test for purpose limitation and the mechanism by which secondary use is either justified or ruled out. It is skipped almost universally: organizations extend processing to new purposes without performing the assessment, which means the compatibility judgment the Regulation requires was simply never made.

HOW TO AUDIT IT

1. Identify secondary uses of data collected for other purposes.
2. Check whether a compatibility assessment was performed for each, addressing the listed factors.
3. Examine analytics, product development, and model training as likely secondary uses.
4. Verify the assessment considers consequences for data subjects, not only organizational benefit.

EVIDENCE TO COLLECT

- Compatibility assessments per secondary use
- Secondary use inventory

HOW TO DOCUMENT IT

List secondary uses with no compatibility assessment, since the absence of the assessment is the finding regardless of whether the use would have passed it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is used for purposes beyond those of collection without any compatibility assessment, so the organization has not performed the analysis the Regulation requires before extending processing.

Art. 7 Conditions for consent

WHAT THE ARTICLE REQUIRES

Where processing is based on consent, the controller must be able to demonstrate that the data subject consented. A written declaration concerning other matters must present the consent request in a clearly distinguishable, intelligible, and easily accessible form. The data subject may withdraw consent at any time, as easily as it was given, and must be informed of this before consenting. Consent is not freely given if performance of a contract is conditional on consent to processing not necessary for that contract.

WHY IT EXISTS

Valid consent is demanding, and consent obtained through bundled acceptance, pre-ticked boxes, or as a condition of service is invalid, which means the processing has no basis at all. The withdrawal requirement is the one most often failed operationally: consent is easy to give through a single click and withdrawal requires contacting support.

HOW TO AUDIT IT

1. Examine how consent is actually obtained, testing the interface rather than reading the policy.
2. Verify consent is unbundled, affirmative, and not a condition of unrelated service.
3. Compare the effort to withdraw against the effort to give, since parity is required.
4. Check consent records demonstrate who consented, when, to what, and how.

EVIDENCE TO COLLECT

- Consent interfaces as presented
- Consent records with scope and timestamp
- Withdrawal mechanism and comparison to giving

HOW TO DOCUMENT IT

Record the number of steps to give consent against the number to withdraw it, since this comparison is concrete, testable, and directly reflects the Article 7(3) requirement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: consent is given through a single action but withdrawal requires a written request and manual processing, so withdrawal is materially harder than consent and the consent relied upon is invalid.

Art. 8 Child's consent for information society services

WHAT THE ARTICLE REQUIRES

Where information society services are offered directly to a child and processing is based on consent, that consent is lawful only where the child is at least 16, or younger with authorisation from the holder of parental responsibility. Member States may provide a lower age, not below 13. The controller must make reasonable efforts to verify that consent is given or authorised by the holder of parental responsibility, taking account of available technology.

WHY IT EXISTS

Children merit specific protection because they are less aware of the risks and consequences of processing. The verification obligation is qualified by reasonableness and available technology, but the common position of no verification at all does not meet it. The variable national age threshold also means a single approach may not work across the Union.

HOW TO AUDIT IT

1. Determine whether services are offered directly to children and whether consent is the basis.
2. Check age verification measures and whether they constitute reasonable efforts.
3. Verify parental authorisation is obtained and verified where the child is below the applicable age.
4. Confirm the applicable age threshold per Member State served.

EVIDENCE TO COLLECT

- Age verification measures
- Parental authorisation records
- Member State age threshold analysis

HOW TO DOCUMENT IT

Record what verification is actually performed, since a self-declared date of birth with no corroboration is unlikely to constitute reasonable efforts for a service known to attract children.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the service is used by children below the applicable age with no verification beyond self-declaration and no parental authorisation, so consent for that processing is not valid.

Art. 9 Special categories of personal data

WHAT THE ARTICLE REQUIRES

Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and processing of genetic data, biometric data for the purpose of uniquely identifying a person, health data, or data concerning sex life or sexual orientation, is prohibited unless one of the Article 9(2) conditions applies. A condition under Article 9 is required in addition to an Article 6 basis, not instead of one.

WHY IT EXISTS

These categories carry heightened risk of discrimination and serious harm, so the default is prohibition with narrow exceptions. Two errors are common: relying on an Article 6 basis alone without an Article 9 condition, and failing to recognise that data revealing a special category is itself special category data, which captures inference and proxies as well as declared fields.

HOW TO AUDIT IT

1. Identify special category data held, including data revealing a special category by inference.
2. Verify an Article 9(2) condition is identified in addition to the Article 6 basis.
3. Examine free-text fields, images, and inferred attributes, since these frequently contain special category data unrecognised as such.
4. Check the safeguards the chosen condition requires are actually in place.

EVIDENCE TO COLLECT

- Special category data inventory including inferred data
- Article 9(2) conditions with Article 6 bases
- Condition-specific safeguards

HOW TO DOCUMENT IT

Record special category data the organization does not recognise as such, particularly inferred attributes and free-text content, since these are processed with none of the required conditions or safeguards.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization processes health and ethnicity data inferred from other attributes without recognising it as special category data, so it is processed with no Article 9 condition and none of the required safeguards.

Art. 10 Personal data relating to criminal convictions and offences

WHAT THE ARTICLE REQUIRES

Processing of personal data relating to criminal convictions and offences, or related security measures, may be carried out only under the control of official authority or when authorised by Union or Member State law providing appropriate safeguards. A comprehensive register of criminal convictions may be kept only under the control of official authority.

WHY IT EXISTS

Criminal offence data sits outside Article 9 but carries comparable risk of exclusion and stigma, and the permission structure is narrower: it requires official authority or specific legal authorisation rather than any of the Article 9(2) routes. Organizations conducting screening frequently process this data without the required legal authorisation.

HOW TO AUDIT IT

1. Identify processing of criminal conviction or offence data, including screening and vetting.
2. Verify the specific Union or Member State legal authorisation relied upon.
3. Check the safeguards that authorisation requires are implemented.
4. Confirm no comprehensive register is maintained outside official authority.

EVIDENCE TO COLLECT

- Criminal offence data inventory
- Legal authorisation with citation
- Required safeguards evidence

HOW TO DOCUMENT IT

Record the specific legal authorisation cited, since a general reference to legitimate interests or employment purposes does not satisfy Article 10.

EXECUTIVE SUMMARY TREATMENT

Suggested language: criminal record data is processed for screening without identifying the Union or Member State law authorising it, so the processing lacks the specific legal foundation Article 10 requires.

Art. 11 Processing not requiring identification

WHAT THE ARTICLE REQUIRES

If the purposes for which a controller processes personal data do not or no longer require identification of a data subject, the controller is not obliged to maintain, acquire, or process additional information to identify the data subject solely to comply with the Regulation. Where the controller can demonstrate it is not in a position to identify the data subject, it must inform the data subject if possible, and Articles 15 to 20 do not apply unless the data subject provides additional identifying information.

WHY IT EXISTS

This provision prevents the perverse outcome of controllers collecting more identifying data in order to service rights requests. It is a genuine limit, but it is also misused as a general excuse for not fulfilling requests where the controller could in fact identify the individual with information it already holds.

HOW TO AUDIT IT

1. Where Article 11 is relied upon to decline rights requests, test whether identification is genuinely impossible.
2. Check the controller is not acquiring additional identifying data solely for compliance.
3. Verify data subjects are informed where the controller cannot identify them.

EVIDENCE TO COLLECT

- Article 11 determinations
- Rights requests declined on identification grounds

HOW TO DOCUMENT IT

Record requests declined on Article 11 grounds and test whether identification was genuinely impossible, since this is a narrow provision commonly used as a broad exemption.

EXECUTIVE SUMMARY TREATMENT

Suggested language: rights requests are declined on the basis that the data subject cannot be identified, in circumstances where identification would be possible using information the organization already holds.

Rights of the Data Subject

Twelve entries covering Articles 12 to 23. Almost entirely 4

The technical failures here share a single root: personal data is distributed across systems, backups, logs, and unstructured stores that the rights process does not reach. The most productive test for Articles 15, 16, 17, and 21 is the same one each time. Take a sampled request, list the systems actually searched or actioned, and compare against the full inventory of systems holding personal data. The gap is the finding and it is usually substantial.

Article 22 is the provision with the most direct bearing on AI systems, and the contested word is 'solely'. Nominal human involvement does not remove a decision from its scope: if the reviewer confirms the automated output without meaningful review, the decision is solely automated in substance. Report override rate and time allocated per decision, because those two figures settle the question. Article 12 governs the mechanics of every other right, and its one-month clock plus the requirement to notify any extension within that same month are the procedural failures found most often.

Quick reference: Data Subject Rights

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [CYB](#) or [AI](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Art. 12^{4%}	Transparent information and modalities for exercising rights	Rights request log with receipt and response dates
Art. 13^{4%}	Information where data is collected from the data subject	Privacy notices as presented at each collection point
Art. 14^{4%}	Information where data is not obtained from the data subject	Inventory of indirectly obtained data with sources
Art. 15^{4%}	Right of access	Access request responses with search scope
Art. 16^{4%}	Right to rectification	Rectification requests with propagation evidence
Art. 17^{4%}	Right to erasure	Erasure requests with ground assessment
Art. 18^{4%}	Right to restriction of processing	Restriction mechanism and its technical effect
Art. 19^{4%}	Notification obligation regarding rectification, erasure, or restriction	Recipient tracking records
Art. 20^{4%}	Right to data portability	Portability responses with actual format
Art. 21^{4%}	Right to object	Objection records and cessation evidence
Art. 22^{4%}	Automated individual decision-making, including profiling	Inventory of automated decisions with effects assessment
Art. 23	Restrictions under Union or Member State law	Restriction decisions with legislative citation

Art. 12 Transparent information and modalities for exercising rights

WHAT THE ARTICLE REQUIRES

The controller must provide information and communications relating to processing in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, particularly for information addressed to a child. Information must be provided without undue delay and in any event within one month of a request, extendable by two further months where necessary given complexity and number of requests, with the data subject informed of any extension within one month. Information is provided free of charge; manifestly unfounded or excessive requests may attract a reasonable fee or be refused, with the controller bearing the burden of demonstrating this.

WHY IT EXISTS

Article 12 governs how every other right is exercised, so a failure here defeats rights that are otherwise properly supported. The one-month clock and the requirement to notify extension within that month are the mechanical failures most often found, and the burden of proof on refusals sits with the controller.

HOW TO AUDIT IT

1. Sample rights requests and measure elapsed time from receipt to substantive response.
2. Check extensions were notified within the first month and were justified rather than routine.
3. Verify the request channel is accessible and that requests made through unexpected channels are recognised.
4. Examine refusals for documented justification, since the burden rests with the controller.

EVIDENCE TO COLLECT

- Rights request log with receipt and response dates
- Extension notifications with dates and reasons
- Refusal decisions with justification
- Request channels and their accessibility

HOW TO DOCUMENT IT

Measure response times from actual receipt rather than from internal logging, since the gap between the two is often where the deadline is lost. Record extensions notified late, which is a discrete breach independent of the eventual response.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of rights requests exceeded the one-month deadline, and extensions were notified after the deadline had already passed, so the procedural requirements of Article 12 were not met even where the substantive response was adequate.

Art. 13 Information where data is collected from the data subject**WHAT THE ARTICLE REQUIRES**

Where personal data is collected from the data subject, the controller must provide, at the time of collection, the identity and contact details of the controller and any data protection officer, the purposes and legal basis, any legitimate interests relied upon, recipients or categories of recipients, transfer details, retention period or criteria, the data subject's rights, the right to withdraw consent, the right to lodge a complaint, whether provision is statutory or contractual and the consequences of not providing, and the existence of automated decision-making with meaningful information about the logic involved.

WHY IT EXISTS

This is the notice that makes transparency real, and it must be given at the time of collection rather than made available somewhere. The elements most often missing are the retention period, the specific legitimate interests relied upon, and meaningful information about automated decision-making logic.

HOW TO AUDIT IT

1. Obtain notices as actually presented and check each required element against the list.
2. Verify the notice is provided at collection rather than merely published.
3. Check retention periods are stated specifically rather than as until no longer required.
4. Examine the automated decision-making disclosure for meaningful information about logic.

EVIDENCE TO COLLECT

- Privacy notices as presented at each collection point
- Element-by-element completeness check
- Automated decision-making disclosures

HOW TO DOCUMENT IT

Check each required element against each collection point rather than against the main privacy policy, since secondary collection points routinely carry no notice at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: privacy notices omit retention periods and the specific legitimate interests relied upon, and a stated number of collection points provide no notice at all.

Art. 14 Information where data is not obtained from the data subject**WHAT THE ARTICLE REQUIRES**

Where data is not obtained from the data subject, the controller must provide the Article 13 information plus the categories of data concerned and the source of the data, including whether it came from publicly accessible sources. Information must be given within a reasonable period and at the latest within one month, or at first communication with the data subject, or at first disclosure to another recipient, whichever is earliest. Exceptions apply where provision is impossible or would involve disproportionate effort, or where obtaining or disclosure is expressly laid down by law.

WHY IT EXISTS

This is the harder notice obligation because the data subject does not know the controller holds their data. It applies to data acquired from brokers, partners, public sources, and enrichment services, and it is routinely ignored entirely on the assumption that notice is impractical. The disproportionate effort exception is narrower than commonly assumed and must be assessed rather than presumed.

HOW TO AUDIT IT

1. Identify data obtained from sources other than the data subject, including enrichment and third-party acquisition.
2. Verify notice was provided within the required timeframe, or that an exception was assessed and documented.
3. Check the source of the data is disclosed as the article requires.
4. Test any disproportionate effort claim against the actual effort involved.

EVIDENCE TO COLLECT

- Inventory of indirectly obtained data with sources
- Article 14 notices with timing evidence
- Documented exception assessments

HOW TO DOCUMENT IT

Record indirectly obtained data with no Article 14 notice and no documented exception assessment, since this is a common and material gap that organizations rarely recognise.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data acquired from third-party sources is processed without any notice to the individuals concerned and without a documented assessment of whether an exception applies, so those individuals are unaware their data is held.

Art. 15 Right of access

WHAT THE ARTICLE REQUIRES

The data subject has the right to obtain confirmation of whether their personal data is being processed and, where it is, access to the data and to information on purposes, categories of data, recipients, retention period, their rights, the source of the data, and the existence of automated decision-making with meaningful information about the logic involved. The controller must provide a copy of the personal data undergoing processing, and the right to obtain a copy must not adversely affect the rights and freedoms of others.

WHY IT EXISTS

Access is the right that makes the others usable, since a data subject cannot exercise rectification or erasure over data they do not know is held. It is also the hardest to fulfil completely, because personal data is distributed across systems, backups, logs, and unstructured stores that the request process frequently does not reach.

HOW TO AUDIT IT

1. Sample access requests and test completeness against the data the organization actually holds.
2. Check whether the search reaches unstructured stores, email, logs, and backups, or only the primary system.
3. Verify the accompanying information is provided, not only the data itself.
4. Examine redaction practice for third-party data, checking it is applied proportionately rather than as a blanket withholding.

EVIDENCE TO COLLECT

- Access request responses with search scope
- Systems searched against the full processing inventory
- Redaction decisions and rationale

HOW TO DOCUMENT IT

Compare the systems searched for a sampled request against the full inventory of systems holding personal data. The gap is the finding, and it is usually substantial.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access requests are fulfilled by searching the primary customer system only, while personal data is held in a stated number of additional systems, so responses are materially incomplete.

Art. 16 Right to rectification

WHAT THE ARTICLE REQUIRES

The data subject has the right to obtain rectification of inaccurate personal data without undue delay, and, taking account of the purposes of processing, to have incomplete data completed, including by means of a supplementary statement.

WHY IT EXISTS

Rectification is straightforward in principle and fails in propagation: correcting the record in one system while copies, downstream systems, and recipients retain the inaccurate version means the wrong data continues to drive decisions. The completion limb is also frequently overlooked, since incomplete data can be as misleading as inaccurate data.

HOW TO AUDIT IT

1. Sample rectification requests and trace the correction through all systems holding the data.
2. Check whether recipients were notified under Article 19.
3. Verify the completion right is supported, not only correction of existing values.
4. Examine handling of disputed accuracy where the controller disagrees.

EVIDENCE TO COLLECT

- Rectification requests with propagation evidence
- Downstream system and recipient notification records

HOW TO DOCUMENT IT

Trace a rectification through every system holding the data and record where the uncorrected value persists, since partial rectification leaves the original inaccuracy operative.

EXECUTIVE SUMMARY TREATMENT

Suggested language: rectifications are applied to the source system only, with a stated number of downstream systems and external recipients retaining uncorrected data.

Art. 17 Right to erasure

WHAT THE ARTICLE REQUIRES

The data subject has the right to obtain erasure without undue delay where the data is no longer necessary, consent is withdrawn and no other basis applies, the data subject objects and there are no overriding legitimate grounds, the data has been unlawfully processed, erasure is required for legal compliance, or the data was collected in relation to information society services offered to a child. Where the controller has made the data public it must take reasonable steps to inform other controllers. Exceptions include freedom of expression, legal obligations, public interest, archiving and research, and legal claims.

WHY IT EXISTS

Erasure is conditional rather than absolute, which cuts both ways: organizations both over-refuse by treating it as never applicable and over-comply by deleting data they are obliged to retain. The technical challenge is comparable to access: erasing from the primary system while backups and derived datasets retain the data does not discharge the obligation.

HOW TO AUDIT IT

1. Sample erasure requests and test whether the assessment against the Article 17(1) grounds was performed.
2. Trace erasure through all systems, including backups, archives, and derived datasets.
3. Check whether refusals cite a valid Article 17(3) exception with reasoning.
4. Examine how backup retention is reconciled with erasure obligations.

EVIDENCE TO COLLECT

- Erasure requests with ground assessment
- Erasure propagation evidence across systems
- Refusal decisions with exception cited
- Backup handling approach for erasure

HOW TO DOCUMENT IT

Record how backups are handled, since a documented and reasoned approach is expected even though immediate backup erasure may not be feasible. An organization with no position at all is the finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: erasure is performed in production systems only, with no documented approach to data persisting in backups and derived datasets, so erased data remains recoverable and in use indefinitely.

Art. 18 Right to restriction of processing

WHAT THE ARTICLE REQUIRES

The data subject has the right to obtain restriction of processing where accuracy is contested, for a period enabling verification; where processing is unlawful and the data subject opposes erasure; where the controller no longer needs the data but the data subject requires it for legal claims; or pending verification of an objection under Article 21. Restricted data may, with the exception of storage, be processed only with consent, for legal claims, to protect another person's rights, or for important public interest. The data subject must be informed before restriction is lifted.

WHY IT EXISTS

Restriction is the least implemented right because it requires a system state between active and deleted, which most systems do not support. Organizations frequently claim to offer restriction while having no technical mechanism to enforce it, meaning restricted data continues to be processed normally.

HOW TO AUDIT IT

1. Verify a technical mechanism exists to restrict processing while retaining data.
2. Test whether restricted records are genuinely excluded from processing, rather than only flagged.
3. Check the data subject is informed before restriction is lifted.
4. Examine whether restriction is offered where accuracy is contested pending verification.

EVIDENCE TO COLLECT

- Restriction mechanism and its technical effect
- Restricted records and evidence of exclusion from processing
- Notification records before lifting

HOW TO DOCUMENT IT

Test whether a restriction flag actually prevents processing or is merely advisory, since a flag that no downstream process reads provides no restriction at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: restriction is recorded as a flag that no downstream system acts upon, so data subject to restriction continues to be processed normally and the right is not implemented.

Art. 19 Notification obligation regarding rectification, erasure, or restriction**WHAT THE ARTICLE REQUIRES**

The controller must communicate any rectification, erasure, or restriction of processing to each recipient to whom the data has been disclosed, unless this proves impossible or involves disproportionate effort. The controller must inform the data subject about those recipients if the data subject requests it.

WHY IT EXISTS

Without this, correcting or erasing data at the controller leaves the incorrect or erased data in circulation with every recipient. The obligation is what makes rights effective beyond the controller's own systems, and it requires the controller to know who its recipients are, which many do not track at the record level.

HOW TO AUDIT IT

1. Check whether recipients are tracked at a level allowing notification.
2. Sample rectifications and erasures and verify recipients were notified.
3. Verify the data subject can obtain the list of recipients on request.
4. Test any impossibility or disproportionate effort claim.

EVIDENCE TO COLLECT

- Recipient tracking records
- Notification evidence for sampled rights actions

HOW TO DOCUMENT IT

Record whether the organization can identify recipients of a specific individual's data, since without that capability Article 19 cannot be complied with regardless of intent.

EXECUTIVE SUMMARY TREATMENT

Suggested language: recipients of personal data are not tracked at individual record level, so rectifications and erasures are not communicated to recipients and inaccurate or erased data remains in circulation.

Art. 20 Right to data portability

WHAT THE ARTICLE REQUIRES

Where processing is based on consent or contract and carried out by automated means, the data subject has the right to receive the personal data they have provided in a structured, commonly used, and machine-readable format, and to transmit it to another controller without hindrance. Where technically feasible, they may have it transmitted directly. The right applies only to data provided by the data subject and must not adversely affect the rights and freedoms of others.

WHY IT EXISTS

Portability is narrower than access: it covers only data provided by the data subject, only where the basis is consent or contract, and only automated processing. It excludes inferred and derived data. The practical failures are providing data in a format that is technically machine-readable but not usable, and applying the right beyond its actual scope.

HOW TO AUDIT IT

1. Verify portability is offered where the basis is consent or contract and processing is automated.
2. Check the format is genuinely structured and machine-readable rather than a PDF.
3. Confirm the scope covers data provided by the data subject, including through observation of their activity.
4. Verify no hindrance is placed on transmission to another controller.

EVIDENCE TO COLLECT

- Portability responses with actual format
- Scope determination for provided data

HOW TO DOCUMENT IT

Record the format actually supplied, since a PDF export does not meet the machine-readable requirement regardless of how complete its contents are.

EXECUTIVE SUMMARY TREATMENT

Suggested language: portability requests are fulfilled with PDF documents rather than a structured machine-readable format, so the data cannot be transmitted to another controller as the right intends.

Art. 21 Right to object

WHAT THE ARTICLE REQUIRES

The data subject has the right to object at any time to processing based on public interest or legitimate interests, including profiling. The controller must cease processing unless it demonstrates compelling legitimate grounds overriding the data subject's interests, rights, and freedoms, or for legal claims. Where data is processed for direct marketing, the data subject may object at any time and the controller must cease processing for that purpose absolutely, with no balancing. This right must be brought to the data subject's attention explicitly and separately at the latest at first communication.

WHY IT EXISTS

The direct marketing limb is absolute: there is no balancing and no exception, and the controller must stop. The general limb reverses the burden onto the controller to demonstrate compelling grounds, which is a higher standard than the original legitimate interests balance. The requirement to present the right explicitly and separately is frequently missed.

HOW TO AUDIT IT

1. Verify marketing objections result in cessation without exception or delay.
2. Check the right to object is presented explicitly and separately, not buried in a privacy notice.
3. For general objections, examine whether compelling grounds were demonstrated rather than asserted.
4. Test whether objection propagates across all marketing channels and systems.

EVIDENCE TO COLLECT

- Objection records and cessation evidence
- Presentation of the right at first communication
- Compelling grounds assessments

HOW TO DOCUMENT IT

Test whether a marketing objection propagates to every channel, since suppression in one system while another continues to contact the individual is a continuing breach of an absolute right.

EXECUTIVE SUMMARY TREATMENT

Suggested language: marketing objections are applied in the email platform only, and individuals who objected continued to receive communications through other channels, in breach of an unqualified right.

Art. 22 Automated individual decision-making, including profiling

WHAT THE ARTICLE REQUIRES

The data subject has the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning them or similarly significantly affects them. Exceptions apply where the decision is necessary for a contract, authorised by Union or Member State law with suitable safeguards, or based on explicit consent. Where the contract or consent exceptions apply, the controller must implement suitable safeguards including at least the right to obtain human intervention, to express a point of view, and to contest the decision. Such decisions may not be based on special category data except under narrow conditions.

WHY IT EXISTS

This is the provision with the most direct bearing on AI systems, and the two contested terms are solely and significantly. Nominal human involvement does not take a decision outside the article: if the human routinely confirms the automated output without meaningful review, the decision remains solely automated in substance. The safeguards are minimum requirements, not options.

HOW TO AUDIT IT

1. Identify automated decisions with legal or similarly significant effects.
2. Where human involvement is claimed, test whether it is meaningful: measure override rates and time per decision.
3. Verify the three minimum safeguards are implemented and usable in practice.
4. Check whether special category data feeds the decision, directly or by proxy.

EVIDENCE TO COLLECT

- Inventory of automated decisions with effects assessment
- Human involvement evidence with override rates and review time
- Safeguard implementation: intervention, representation, contest

HOW TO DOCUMENT IT

Report override rate and average review time per decision, since these two figures determine whether claimed human involvement is meaningful. An override rate near zero across a high volume indicates the decision is automated in substance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: decisions with significant effects on individuals are presented as human-reviewed, but reviewers override the automated recommendation in a negligible proportion of cases with seconds allocated per decision, so the decisions are solely automated in substance and the required safeguards are absent.

Art. 23 Restrictions under Union or Member State law

WHAT THE ARTICLE REQUIRES

Union or Member State law may restrict the scope of the obligations and rights in Articles 12 to 22 and Article 34, and the Article 5 principles insofar as they correspond, where the restriction respects the essence of fundamental rights and is a necessary and proportionate measure to safeguard specified objectives such as national security, defence, public security, prevention and investigation of criminal offences, and other important public interests. Any such legislative measure must contain specific provisions on purposes, categories of data, safeguards, and the risks to data subjects.

WHY IT EXISTS

Restrictions must have a legislative foundation with specified content; a controller cannot restrict rights on its own assessment that doing so is justified. Organizations sometimes decline rights requests citing security or investigation grounds without identifying the legal measure that permits it, which is not a valid restriction.

HOW TO AUDIT IT

1. Where rights are restricted, identify the specific legislative measure relied upon.
2. Check the restriction is applied within the scope that measure permits.
3. Verify restrictions are not applied on the controller's own assessment absent a legal measure.
4. Confirm any restriction is proportionate and time-bounded rather than blanket.

EVIDENCE TO COLLECT

- Restriction decisions with legislative citation
- Scope analysis of the relied-upon measure

HOW TO DOCUMENT IT

Record the legislative measure cited for each restriction, since a restriction applied without one is simply a failure to fulfil the right.

EXECUTIVE SUMMARY TREATMENT

Suggested language: rights requests are declined on investigation grounds without citing any legislative measure permitting restriction, so the refusals are unlawful failures to fulfil the rights concerned.

Controller and Processor Obligations

Eighteen entries covering Articles 24 to 43, the operational core of the Regulation. Almost entirely 2 Article 30 is where an assessment should start. The record of processing is the foundational artefact, the first document a supervisory authority requests, and the thing every other obligation depends on. Test it against reality for a sample rather than confirming it exists; activities discovered that do not appear in it tell you the record is not maintained, which frames everything else.

Article 25(2) is the most testable provision in the chapter: check defaults on the live system, because a privacy-protective setting that exists but is not the default is a direct finding. Article 33's 72-hour clock runs from awareness, which is earlier than organizations assume, so establish the point of awareness independently rather than accepting the declared date. Article 35 requires DPIAs prior to processing, so compare DPIA dates against processing start dates. And Article 38 is where DPO designations fail in substance: a DPO who also determines purposes and means holds a structural conflict that undermines every task in Article 39.

Quick reference: Controller/Processor

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Art. 24	Responsibility of the controller	Technical and organisational measures with risk linkage
Art. 25^{2%}	Data protection by design and by default	Design-stage data protection evidence
Art. 26^{2%}	Joint controllers	Joint controller determinations
Art. 27^{2%}	Representatives of controllers or processors not established in the Union	Written designation of representative
Art. 28^{2%}	Processor obligations and the processing contract	Processor contracts with term-by-term check
Art. 29^{2%}	Processing under the authority of the controller or processor	Confidentiality and instruction commitments
Art. 30^{2%}	Records of processing activities	Record of processing activities
Art. 31^{2%}	Cooperation with the supervisory authority	Supervisory authority contact process and owner
Art. 32^{2%}	Security of processing	Technical and organisational measures with risk assessment
Art. 33^{2%}	Notification of a personal data breach to the supervisory authority	Breach register including non-notifiable breaches
Art. 34^{2%}	Communication of a personal data breach to the data subject	High risk assessments per breach
Art. 35^{2%}	Data protection impact assessment	DPIAs with completion dates
Art. 36^{2%}	Prior consultation with the supervisory authority	DPIA residual risk conclusions
Art. 37^{2%}	Designation of the data protection officer	DPO designation with qualifications

Ref	Title	Primary evidence
Art. 38 ^{2%}	Position of the data protection officer	DPO role description and other responsibilities
Art. 39 ^{2%}	Tasks of the data protection officer	DPO monitoring and audit activity records
Art. 40-41	Codes of conduct and monitoring	Code adherence declarations
Art. 42-43 ^{2%}	Certification and certification bodies	Certifications held with scope and validity dates

Art. 24 Responsibility of the controller

WHAT THE ARTICLE REQUIRES

Taking into account the nature, scope, context, and purposes of processing and the risks to rights and freedoms, the controller must implement appropriate technical and organisational measures to ensure and be able to demonstrate that processing is performed in accordance with the Regulation. Those measures must be reviewed and updated where necessary, and may include implementing data protection policies where proportionate.

WHY IT EXISTS

Article 24 is the general obligation that the rest of the chapter elaborates, and its operative feature is risk-proportionality: the measures required scale with the risk of the specific processing. It also carries the demonstrability requirement, so measures that exist but cannot be evidenced do not discharge it.

HOW TO AUDIT IT

1. Assess whether measures are proportionate to the risk of the actual processing rather than uniform.
2. Check measures are reviewed and updated, with evidence of review.
3. Verify the organization can demonstrate compliance rather than merely assert it.
4. Look for high-risk processing receiving the same treatment as routine processing.

EVIDENCE TO COLLECT

- Technical and organisational measures with risk linkage
- Review and update records
- Data protection policies

HOW TO DOCUMENT IT

Record whether measures differentiate by risk, since uniform treatment means high-risk processing is under-protected even where the baseline is adequate for routine processing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: data protection measures are applied uniformly regardless of processing risk, so the organization's highest-risk processing receives no greater protection than its most routine.

Art. 25 Data protection by design and by default

WHAT THE ARTICLE REQUIRES

The controller must implement appropriate technical and organisational measures, both at the time of determining the means of processing and at the time of processing itself, designed to implement the data protection principles effectively and integrate necessary safeguards. By default, only personal data necessary for each specific purpose may be processed, covering the amount collected, the extent of processing, the storage period, and accessibility. By default, personal data must not be made accessible to an indefinite number of people without individual intervention.

WHY IT EXISTS

By design requires data protection to be built in at the point of designing, which is the only point at which it is cheap. By default is the more testable limb and the more often breached: the default configuration must be the most privacy-protective one, so a system that collects everything unless the user opts out fails regardless of how good the opt-out is.

HOW TO AUDIT IT

1. Check data protection is considered at design time, examining design documentation for recent projects.
2. Test default settings on live systems: the default must be the minimum necessary.
3. Verify default sharing and visibility settings do not expose data to an indefinite audience.
4. Look for privacy-protective options that exist but are not the default.

EVIDENCE TO COLLECT

- Design-stage data protection evidence
- Default configuration of live systems
- Default visibility and sharing settings

HOW TO DOCUMENT IT

Test defaults on the live system rather than reading the configuration guide. A setting that can be made privacy-protective but is not by default is a direct Article 25(2) finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: system defaults maximise data collection and visibility, with privacy-protective settings available but requiring the individual to seek them out, contrary to the data protection by default requirement.

Art. 26 Joint controllers

WHAT THE ARTICLE REQUIRES

Where two or more controllers jointly determine the purposes and means of processing, they are joint controllers and must determine their respective responsibilities for compliance in a transparent arrangement, in particular regarding the exercise of data subject rights and the provision of information. The essence of the arrangement must be made available to data subjects, and the data subject may exercise their rights against each controller irrespective of the arrangement.

WHY IT EXISTS

Joint controllership arises from the factual reality of joint determination, not from an agreement to be joint controllers, so parties can be joint controllers without having recognised it. The provision that data subjects may exercise rights against either controller regardless of the arrangement means an organization cannot contract its way out of responding.

HOW TO AUDIT IT

1. Identify relationships where purposes and means are jointly determined, regardless of contractual labels.
2. Verify an Article 26 arrangement exists allocating responsibilities.
3. Check the essence of the arrangement is available to data subjects.
4. Confirm the organization can respond to rights requests regardless of the internal allocation.

EVIDENCE TO COLLECT

- Joint controller determinations
- Article 26 arrangements
- Disclosure of the arrangement's essence to data subjects

HOW TO DOCUMENT IT

Record relationships that are factually joint controllership but treated otherwise, since neither party will have made the required arrangement or disclosure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: relationships involving joint determination of purposes are treated as controller-to-processor, so no joint controller arrangement exists and data subjects are not informed of its essence.

Art. 27 Representatives of controllers or processors not established in the Union

WHAT THE ARTICLE REQUIRES

Where Article 3(2) applies, the controller or processor must designate in writing a representative in the Union, in a Member State where data subjects are located. The representative must be mandated to be addressed by supervisory authorities and data subjects on all issues relating to processing, and its designation does not affect legal actions against the controller or processor itself. Exemptions apply for occasional processing that is low risk and excludes special category data at scale.

WHY IT EXISTS

The representative is the contact point that makes an extra-territorial controller reachable, and the obligation is frequently unmet because organizations do not realise Article 3(2) applies to them. The exemption is narrow and requires assessment rather than assumption.

HOW TO AUDIT IT

1. Where Article 3(2) applies, verify a representative is designated in writing and in an appropriate Member State.
2. Check the representative's details are published so data subjects can reach them.
3. Verify the representative is genuinely mandated and responsive rather than nominal.
4. Test any claimed exemption against the conditions.

EVIDENCE TO COLLECT

- Written designation of representative
- Publication of representative details
- Exemption assessment where relied upon

HOW TO DOCUMENT IT

Record whether the representative is reachable in practice, since a designation that data subjects cannot find or contact does not achieve the article's purpose.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization falls within Article 3(2) but has designated no Union representative, so data subjects and supervisory authorities have no mandated point of contact.

Art. 28 Processor obligations and the processing contract

WHAT THE ARTICLE REQUIRES

A controller must use only processors providing sufficient guarantees to implement appropriate measures. Processing by a processor must be governed by a contract setting out the subject matter, duration, nature and purpose, type of data, categories of data subjects, and the controller's obligations and rights. The contract must stipulate that the processor processes only on documented instructions, ensures confidentiality commitments, takes Article 32 measures, respects sub-processor conditions, assists with data subject rights and with Articles 32 to 36, deletes or returns data at the end of provision, and makes available information to demonstrate compliance and allow audits. A processor engaging a sub-processor requires prior authorisation and must impose the same obligations.

WHY IT EXISTS

Article 28 is the mechanism by which obligations flow down a supply chain, and its practical failures are structural: contracts missing required terms, sub-processors engaged without authorisation, and audit rights that exist on paper but have never been exercised. The requirement for sufficient guarantees also means processor selection must involve actual assessment.

HOW TO AUDIT IT

1. Sample processor contracts and check each required Article 28(3) term is present.
2. Verify sufficient guarantees were assessed before engagement rather than assumed.
3. Check sub-processor authorisation exists and that the same obligations flow down.
4. Examine whether audit or information rights have ever been exercised.

EVIDENCE TO COLLECT

- Processor contracts with term-by-term check
- Pre-engagement assessments
- Sub-processor authorisations and flow-down contracts
- Audit exercise records

HOW TO DOCUMENT IT

Record contracts missing required terms and sub-processors engaged without authorisation. Note whether audit rights have ever been exercised, since unexercised rights mean processor compliance is unverified.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of processor contracts omit required Article 28(3) terms, sub-processors are engaged without authorisation, and contractual audit rights have never been exercised, so processor compliance is entirely unverified.

Art. 29 Processing under the authority of the controller or processor

WHAT THE ARTICLE REQUIRES

The processor and any person acting under the authority of the controller or processor who has access to personal data must not process it except on instructions from the controller, unless required to do so by Union or Member State law.

WHY IT EXISTS

This extends the instruction constraint to individuals, closing the gap where a processor organization complies while its staff process data for their own reasons. It is the provision underlying findings about employees accessing records out of curiosity or for personal purposes.

HOW TO AUDIT IT

1. Verify staff with data access are bound to process only on instruction.
2. Check whether access is monitored for processing outside instructions.
3. Examine any identified instances of unauthorised access by authorised users.

EVIDENCE TO COLLECT

- Confidentiality and instruction commitments
- Access monitoring for out-of-instruction processing

HOW TO DOCUMENT IT

Record whether access by authorised users is monitored for legitimacy of purpose, since access control alone does not detect an authorised user acting outside instructions.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access by authorised staff is not monitored for legitimacy of purpose, so processing outside the controller's instructions by people with valid access would not be detected.

Art. 30 Records of processing activities

WHAT THE ARTICLE REQUIRES

Each controller must maintain a record of processing activities under its responsibility, containing the controller's details, purposes, categories of data subjects and personal data, categories of recipients including in third countries, transfers and their safeguards, envisaged retention time limits, and a general description of technical and organisational measures. Processors maintain a corresponding record. Records must be in writing including electronic form and made available to the supervisory authority on request. A limited exemption applies to organizations with fewer than 250 employees, subject to conditions that in practice rarely hold.

WHY IT EXISTS

The record of processing is the foundational compliance artefact: every other obligation depends on knowing what processing occurs. It is also the first document a supervisory authority requests, and its absence or inaccuracy frames everything that follows in an investigation.

HOW TO AUDIT IT

1. Obtain the record and check each required element is present per activity.
2. Test accuracy by comparing entries against the actual processing for a sample.
3. Look for processing activities absent from the record entirely.
4. Check the record is current, with evidence of maintenance.

EVIDENCE TO COLLECT

- Record of processing activities
- Comparison against actual processing
- Maintenance and update evidence

HOW TO DOCUMENT IT

Test the record against reality for a sample of activities rather than checking only that it exists. Record activities discovered that do not appear in it, since these indicate the record is not maintained.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the record of processing activities omits a stated number of processing activities and states retention periods that do not match actual practice, so it does not accurately describe the organization's processing.

Art. 31 Cooperation with the supervisory authority

WHAT THE ARTICLE REQUIRES

The controller and processor, and where applicable their representatives, must cooperate on request with the supervisory authority in the performance of its tasks.

WHY IT EXISTS

Cooperation is a standalone obligation, and failure to cooperate is separately actionable and weighs in any assessment of a fine. Practically, it depends on the organization being able to respond: an organization that cannot locate its own processing records cannot cooperate effectively however willing it is.

HOW TO AUDIT IT

1. Verify a process exists for responding to supervisory authority contact, with a named owner.
2. Check the organization can produce its core compliance documentation promptly.
3. Examine any actual supervisory authority interaction and how it was handled.

EVIDENCE TO COLLECT

- Supervisory authority contact process and owner
- Records of any interactions

HOW TO DOCUMENT IT

Record whether the organization could produce its record of processing, DPIAs, and breach records promptly on request, since cooperation is only meaningful if the material exists and is retrievable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no process exists for responding to supervisory authority enquiries and core compliance documentation is not readily retrievable, so the organization is not positioned to cooperate effectively.

Art. 32 Security of processing

WHAT THE ARTICLE REQUIRES

Taking account of the state of the art, costs of implementation, and the nature, scope, context, and purposes of processing, as well as the risk to rights and freedoms, the controller and processor must implement appropriate technical and organisational measures, including as appropriate pseudonymisation and encryption, the ability to ensure ongoing confidentiality, integrity, availability, and resilience, the ability to restore availability and access in a timely manner after an incident, and a process for regularly testing, assessing, and evaluating effectiveness. Regard must be had in particular to risks from accidental or unlawful destruction, loss, alteration, or unauthorised disclosure of or access to data.

WHY IT EXISTS

Article 32 is risk-based rather than prescriptive, and the named measures are examples rather than requirements. The element most often absent is the last: a process for regularly testing and evaluating effectiveness. Measures implemented and never tested are a common finding, and the article requires the testing explicitly.

HOW TO AUDIT IT

1. Assess measures against the risk of the specific processing, not against a generic baseline.
2. Verify a regular testing and evaluation process exists and has been executed.
3. Check restoration capability has been tested, since availability and resilience are named explicitly.
4. Examine encryption and pseudonymisation decisions and their reasoning where not applied.

EVIDENCE TO COLLECT

- Technical and organisational measures with risk assessment
- Testing and evaluation records
- Restoration testing evidence
- Encryption coverage and decisions

HOW TO DOCUMENT IT

Record whether the regular testing process required by Article 32(1)(d) exists and has produced results, since this is an explicit obligation distinct from having the measures themselves.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security measures have never been tested or evaluated for effectiveness, and restoration from backup has never been exercised, so neither the protective nor the recovery measures required by Article 32 are demonstrably effective.

Art. 33 Notification of a personal data breach to the supervisory authority

WHAT THE ARTICLE REQUIRES

In the case of a personal data breach, the controller must notify the competent supervisory authority without undue delay and where feasible not later than 72 hours after having become aware of it, unless the breach is unlikely to result in a risk to rights and freedoms. Where notification is later than 72 hours it must be accompanied by reasons for the delay. The notification must describe the nature of the breach, the categories and approximate numbers of data subjects and records, the DPO or contact point, likely consequences, and measures taken or proposed. A processor must notify the controller without undue delay. The controller must document all breaches regardless of notifiability.

WHY IT EXISTS

The 72-hour clock runs from awareness, which is earlier than most organizations assume: awareness arises when there is a reasonable degree of certainty a breach has occurred, not when the investigation concludes. The obligation to document all breaches, including non-notifiable ones, is separate and routinely unmet.

HOW TO AUDIT IT

1. Test when awareness arose against when notification was made, for sampled breaches.
2. Verify all breaches are documented, including those assessed as not notifiable.
3. Check the risk assessment supporting any decision not to notify.
4. Examine whether staff can recognise and escalate a breach quickly enough for a 72-hour response.

EVIDENCE TO COLLECT

- Breach register including non-notifiable breaches
- Notification records with awareness and notification timestamps
- Risk assessments for non-notification decisions
- Internal escalation procedures and timings

HOW TO DOCUMENT IT

Establish the point of awareness independently rather than accepting the organization's stated date, since the difference between discovery and formal declaration is where the 72 hours is lost.

EXECUTIVE SUMMARY TREATMENT

Suggested language: breaches were notified beyond 72 hours from the point staff became aware, with the delay attributed to internal escalation, and breaches assessed as non-notifiable are not documented at all.

Art. 34 Communication of a personal data breach to the data subject**WHAT THE ARTICLE REQUIRES**

When a personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller must communicate it to the data subject without undue delay, in clear and plain language, describing the nature of the breach and including the DPO contact, likely consequences, and measures taken. Communication is not required where the controller has applied appropriate protection such as encryption rendering the data unintelligible, has taken subsequent measures ensuring the high risk is no longer likely to materialise, or where it would involve disproportionate effort, in which case a public communication is required instead.

WHY IT EXISTS

Communication to data subjects is triggered by high risk rather than the risk threshold for supervisory notification, so a breach may be notifiable to the authority but not communicable to individuals. The exemptions are specific and must be assessed, and the encryption exemption requires that the data is genuinely unintelligible to those who accessed it.

HOW TO AUDIT IT

1. Check the high risk assessment for each notified breach and the reasoning behind communication decisions.
2. Verify any exemption relied upon is properly established, particularly encryption claims.
3. Examine the clarity and timeliness of communications actually sent.
4. Confirm public communication was used where disproportionate effort was claimed.

EVIDENCE TO COLLECT

- High risk assessments per breach
- Communications sent to data subjects
- Exemption justifications

HOW TO DOCUMENT IT

Record where the encryption exemption is claimed and whether the keys were also exposed, since encrypted data accessed alongside its keys is not unintelligible.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization relied on the encryption exemption to avoid notifying affected individuals, in circumstances where the encryption keys were accessible in the same environment, so the exemption did not apply.

Art. 35 Data protection impact assessment

WHAT THE ARTICLE REQUIRES

Where a type of processing, in particular using new technologies, is likely to result in a high risk to rights and freedoms, the controller must carry out a DPIA prior to processing. A DPIA is required in particular for systematic and extensive evaluation of personal aspects based on automated processing including profiling on which decisions with legal or similarly significant effects are based, for processing of special categories or criminal data on a large scale, and for systematic monitoring of publicly accessible areas on a large scale. The DPIA must contain a systematic description of the processing and purposes, an assessment of necessity and proportionality, an assessment of risks to data subjects, and the measures envisaged to address those risks. The DPO's advice must be sought, and the views of data subjects sought where appropriate.

WHY IT EXISTS

The DPIA is the primary mechanism for identifying risk before processing begins, and the words prior to processing are operative: a DPIA completed after deployment has failed its purpose even if its content is sound. The necessity and proportionality assessment is the element most often reduced to assertion, and it is the substantive core of the exercise.

HOW TO AUDIT IT

1. Identify processing meeting the Article 35(3) criteria and verify DPIAs exist for each.
2. Check DPIA dates against processing start dates, since prior completion is the requirement.
3. Examine the necessity and proportionality assessment for genuine analysis rather than assertion.
4. Verify DPO advice was sought and that data subject views were considered where appropriate.

EVIDENCE TO COLLECT

- DPIAs with completion dates
- Processing start dates for comparison
- DPO advice records
- Screening determinations for processing assessed as not requiring a DPIA

HOW TO DOCUMENT IT

Compare DPIA completion dates against processing start dates and record any completed after processing began. Also record processing that met the criteria but received no DPIA and no documented screening decision.

EXECUTIVE SUMMARY TREATMENT

Suggested language: DPIAs for high-risk processing were completed after processing had already begun, and a stated number of activities meeting the mandatory criteria have no DPIA and no documented screening decision.

Art. 36 Prior consultation with the supervisory authority

WHAT THE ARTICLE REQUIRES

The controller must consult the supervisory authority prior to processing where a DPIA indicates that the processing would result in a high risk in the absence of measures taken by the controller to mitigate the risk. When consulted, the authority must provide written advice within eight weeks, extendable by six weeks, and may exercise its powers. The controller must provide specified information including respective responsibilities, purposes and means, measures and safeguards, DPO contact details, and the DPIA.

WHY IT EXISTS

Prior consultation is the escalation route when residual risk remains high after mitigation, and it is almost never used, which is itself informative: either no processing carries high residual risk, or DPIAs are concluding that risk is mitigated when it is not. The latter is far more likely.

HOW TO AUDIT IT

1. Examine DPIAs concluding high residual risk and check whether consultation followed.
2. Assess whether DPIA conclusions of mitigated risk are supported by the mitigations actually implemented.
3. Verify any consultation performed provided the required information.

EVIDENCE TO COLLECT

- DPIA residual risk conclusions
- Consultation records where applicable
- Mitigation implementation evidence

HOW TO DOCUMENT IT

Where no DPIA has ever concluded high residual risk, examine whether mitigations claimed are actually implemented, since a consistent conclusion of adequate mitigation across all high-risk processing warrants scrutiny.

EXECUTIVE SUMMARY TREATMENT

Suggested language: DPIAs uniformly conclude that residual risk is adequately mitigated, including where the mitigating measures relied upon have not been implemented, so prior consultation has been avoided on an unsupported basis.

Art. 37 Designation of the data protection officer

WHAT THE ARTICLE REQUIRES

A DPO must be designated where processing is carried out by a public authority or body, where core activities consist of processing operations requiring regular and systematic monitoring of data subjects on a large scale, or where core activities consist of processing special categories or criminal data on a large scale. The DPO must be designated on the basis of professional qualities and expert knowledge of data protection law and practice, may be a staff member or fulfil the tasks under a service contract, and the contact details must be published and communicated to the supervisory authority.

WHY IT EXISTS

The designation triggers are frequently misjudged, particularly the core activities test: processing is a core activity where it is inextricably linked to the organization's primary function, not merely where it is substantial. Public authorities must designate regardless of scale, which is the clearest trigger and still sometimes missed.

HOW TO AUDIT IT

1. Assess whether the designation criteria apply, documenting the reasoning.
2. Where a DPO is designated, verify expert knowledge appropriate to the processing.
3. Check contact details are published and communicated to the supervisory authority.
4. Where no DPO is designated, examine the documented basis for that conclusion.

EVIDENCE TO COLLECT

- DPO designation with qualifications
- Published contact details and communication to the authority
- Designation assessment where no DPO appointed

HOW TO DOCUMENT IT

Record whether the designation decision was assessed and documented, since an undocumented conclusion that no DPO is required is itself an accountability failure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not designated a DPO and holds no documented assessment of whether the mandatory criteria apply, despite conducting large-scale processing of special category data.

Art. 38 Position of the data protection officer

WHAT THE ARTICLE REQUIRES

The controller and processor must ensure the DPO is involved properly and in a timely manner in all issues relating to the protection of personal data, support the DPO by providing resources and access to personal data and processing operations and to maintain expert knowledge, and ensure the DPO receives no instructions regarding the exercise of their tasks. The DPO must not be dismissed or penalised for performing their tasks, must report to the highest management level, may be contacted by data subjects, and is bound by secrecy or confidentiality. The DPO may fulfil other tasks provided they do not result in a conflict of interests.

WHY IT EXISTS

The independence and conflict-of-interest requirements are where designations most often fail in substance. A DPO who also determines the purposes and means of processing, such as a head of IT or of marketing, holds a structural conflict, and a DPO reporting into a function whose processing they must challenge is not independent regardless of the job title.

HOW TO AUDIT IT

1. Examine the DPO's other responsibilities for conflicts, particularly roles determining purposes and means.
2. Verify the reporting line reaches the highest management level.
3. Check the DPO is involved early in projects rather than consulted at the end.
4. Assess whether resources are adequate for the scale of processing.

EVIDENCE TO COLLECT

- DPO role description and other responsibilities
- Reporting line evidence
- Project involvement records showing timing
- Resource allocation

HOW TO DOCUMENT IT

Record the DPO's other roles and reporting line, since a conflicted or subordinated DPO is a structural finding that undermines every task in Article 39.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the designated DPO also heads a function that determines the purposes and means of processing and reports below the highest management level, so the independence Article 38 requires is absent.

Art. 39 Tasks of the data protection officer

WHAT THE ARTICLE REQUIRES

The DPO must inform and advise the controller or processor and employees of their obligations, monitor compliance including assignment of responsibilities, awareness-raising and training, and audits, provide advice on DPIAs and monitor their performance, cooperate with the supervisory authority, and act as contact point for the authority. The DPO must have due regard to the risk associated with processing operations, taking account of nature, scope, context, and purposes.

WHY IT EXISTS

Monitoring compliance is an active obligation requiring the DPO to check rather than to be told, and the audit function within it is often absent entirely. The risk-based framing means the DPO's attention should concentrate on high-risk processing rather than distribute evenly.

HOW TO AUDIT IT

1. Verify the DPO actively monitors compliance, including through audits, rather than responding to queries.
2. Check DPIA advice was provided and DPIA performance monitored.
3. Examine whether monitoring is risk-prioritised.
4. Confirm the DPO acts as contact point for the supervisory authority.

EVIDENCE TO COLLECT

- DPO monitoring and audit activity records
- DPIA advice records
- Training and awareness activity

HOW TO DOCUMENT IT

Record whether the DPO has conducted any independent monitoring or audit, since a purely advisory DPO responding to requests is not performing the monitoring task Article 39(1)(b) requires.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the DPO operates purely as an advisory contact, having conducted no independent monitoring or audit of compliance across the period, so the monitoring task the Regulation assigns is not being performed.

Art. 40-41 Codes of conduct and monitoring**WHAT THE ARTICLE REQUIRES**

Associations representing categories of controllers or processors may prepare codes of conduct specifying the application of the Regulation, which are submitted to the supervisory authority for approval. Adherence to an approved code may be used to demonstrate compliance. Monitoring of compliance with a code may be carried out by a body with an appropriate level of expertise accredited by the competent supervisory authority, which must take appropriate action in cases of infringement including suspension or exclusion.

WHY IT EXISTS

Codes of conduct are a voluntary mechanism, but adherence carries consequences: it can be used to demonstrate compliance under Article 24, and it brings binding monitoring with the possibility of exclusion. An organization claiming adherence without meeting the code's requirements creates exposure rather than reducing it.

HOW TO AUDIT IT

1. Establish whether the organization claims adherence to any approved code.
2. Where it does, verify compliance with the code's requirements and submission to its monitoring.
3. Check whether adherence is being used to demonstrate compliance and whether that is warranted.

EVIDENCE TO COLLECT

- Code adherence declarations
- Monitoring body engagement records
- Compliance with code requirements

HOW TO DOCUMENT IT

Record whether claimed code adherence is matched by actual compliance and by submission to monitoring, since a claim without substance is a misrepresentation as well as a compliance gap.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization publicly claims adherence to an approved code of conduct without having submitted to the code's monitoring body, so the claim is unsupported.

Art. 42-43 Certification and certification bodies**WHAT THE ARTICLE REQUIRES**

Member States, supervisory authorities, the Board, and the Commission must encourage the establishment of data protection certification mechanisms, seals, and marks to demonstrate compliance. Certification is voluntary, available via a transparent process, and does not reduce the responsibility of the controller or processor. Certification is issued for a maximum of three years and may be renewed or withdrawn. Certification bodies must have an appropriate level of expertise and be accredited by the competent supervisory authority or national accreditation body, and are responsible for the proper assessment leading to certification or its withdrawal.

WHY IT EXISTS

The critical provision is that certification does not reduce responsibility: a certified controller remains fully accountable, and certification is evidence rather than a defence. Organizations sometimes treat a certificate or seal as discharging obligations, which it does not, and certifications obtained from non-accredited bodies carry no standing at all.

HOW TO AUDIT IT

1. Establish what certifications are held and whether the issuing body is accredited.
2. Check certification scope against the processing it is claimed to cover.
3. Verify certification is current, given the three-year maximum.
4. Confirm certification is not being treated as discharging responsibility.

EVIDENCE TO COLLECT

- Certifications held with scope and validity dates
- Accreditation status of issuing bodies

HOW TO DOCUMENT IT

Record the scope of any certification against the processing to which it is applied, since a narrow certification presented as organization-wide assurance is a misrepresentation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a certification covering a single system is presented as organization-wide assurance, and the issuing body is not accredited by a competent supervisory authority, so the certification carries no weight for the processing it is relied upon to cover.

International Transfers

Six entries on Chapter V. Entirely 4

Start by compiling the transfer inventory independently rather than accepting the stated one. Remote support access from a third country is a transfer, cloud processing locations are transfers, and onward transfers by processors and sub-processors are within scope. Organizations routinely secure the first hop and lose sight of what happens after it, so the transfers with no mechanism at all are usually the ones nobody recognised as transfers.

For Article 46, executing standard contractual clauses is necessary but not sufficient. The transferring party must assess whether the law and practice of the destination country prevent the clauses being effective, and implement supplementary measures where it does. That assessment is frequently absent, which leaves clauses in place that cannot deliver what they promise. Article 49 derogations are for specific situations and cannot support routine systematic flows, however convenient that reading would be.

Quick reference: Transfers

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Art. 44^{4%}	General principle for transfers	Transfer inventory with destinations
Art. 45^{4%}	Transfers on the basis of an adequacy decision	Adequacy reliance per transfer with decision cited
Art. 46^{4%}	Transfers subject to appropriate safeguards	Executed clauses with version and module
Art. 47^{4%}	Binding corporate rules	Approval evidence from the competent authority
Art. 48^{4%}	Transfers or disclosures not authorised by Union law	Process for handling third-country authority demands
Art. 49^{4%}	Derogations for specific situations	Derogation reliance per transfer

Art. 44 General principle for transfers

WHAT THE ARTICLE REQUIRES

Any transfer of personal data undergoing processing or intended for processing after transfer to a third country or international organisation may take place only if the conditions in Chapter V are complied with by the controller and processor, including for onward transfers to another third country or international organisation. All provisions of the chapter must be applied to ensure the level of protection guaranteed by the Regulation is not undermined.

WHY IT EXISTS

This is the governing principle for the chapter, and its operative feature is that it follows the data: onward transfers are covered, so a compliant transfer to one country followed by an uncontrolled onward transfer breaches the chapter. Organizations frequently secure the first hop and lose sight of what happens after.

HOW TO AUDIT IT

1. Compile the actual transfer inventory, including transfers arising from remote support access and cloud processing locations.
2. Verify a Chapter V mechanism exists for each transfer.
3. Trace onward transfers by processors and sub-processors.
4. Check that support access from third countries is recognised as a transfer.

EVIDENCE TO COLLECT

- Transfer inventory with destinations
- Chapter V mechanism per transfer
- Onward transfer mapping

HOW TO DOCUMENT IT

Compile transfers independently from processor locations and support arrangements rather than accepting the stated list, since remote access from a third country is a transfer that inventories routinely omit.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data is accessible from third countries through support arrangements that are not recognised as transfers, so a stated number of transfers occur with no Chapter V mechanism at all.

Art. 45 Transfers on the basis of an adequacy decision**WHAT THE ARTICLE REQUIRES**

A transfer may take place where the Commission has decided that the third country, a territory or specified sectors within it, or the international organisation ensures an adequate level of protection. Such a transfer requires no specific authorisation. The Commission monitors developments that could affect adequacy decisions and may repeal, amend, or suspend them, and decisions are subject to periodic review.

WHY IT EXISTS

Adequacy is the simplest mechanism and the least stable: decisions can be invalidated or suspended, and organizations relying solely on adequacy without a fallback face an immediate compliance gap when that happens. The scope of a decision also matters, since some cover only specific sectors or frameworks rather than a whole country.

HOW TO AUDIT IT

1. Verify claimed adequacy decisions are current and cover the specific destination and sector.
2. Check whether the transfer falls within the decision's actual scope rather than the country generally.
3. Assess whether a fallback mechanism exists should adequacy be withdrawn.

EVIDENCE TO COLLECT

- Adequacy reliance per transfer with decision cited
- Scope analysis of the decision
- Contingency arrangements

HOW TO DOCUMENT IT

Record whether adequacy reliance is scoped correctly and whether a fallback exists, since the history of invalidated arrangements makes this a live rather than theoretical concern.

EXECUTIVE SUMMARY TREATMENT

Suggested language: transfers rely on an adequacy decision covering only a specific certification framework, while the recipients concerned are not within it, so those transfers have no valid basis.

Art. 46 Transfers subject to appropriate safeguards**WHAT THE ARTICLE REQUIRES**

In the absence of adequacy, a transfer may take place where the controller or processor has provided appropriate safeguards and enforceable data subject rights and effective legal remedies are available. Safeguards may be provided by a legally binding instrument between public authorities, binding corporate rules, standard contractual clauses adopted or approved by the Commission, an approved code of conduct with binding commitments, or an approved certification mechanism with binding commitments.

WHY IT EXISTS

Standard contractual clauses are the most used mechanism, and executing them is necessary but not sufficient: the transferring party must assess whether the law and practice of the destination country prevent the clauses being effective, and implement supplementary measures where it does. That assessment is frequently absent, leaving clauses in place that cannot deliver what they promise.

HOW TO AUDIT IT

1. Verify the correct current version of the clauses is in place with the appropriate module for the relationship.
2. Check a transfer impact assessment was performed for the destination country.
3. Where risks were identified, verify supplementary measures were implemented rather than only considered.
4. Confirm data subjects can actually enforce the third-party beneficiary rights the clauses create.

EVIDENCE TO COLLECT

- Executed clauses with version and module
- Transfer impact assessments per destination
- Supplementary measures implemented

HOW TO DOCUMENT IT

Record whether transfer impact assessments exist and whether identified risks led to actual supplementary measures, since clauses executed without that analysis do not provide the safeguards the article requires.

EXECUTIVE SUMMARY TREATMENT

Suggested language: standard contractual clauses are in place without any assessment of whether the destination country's law permits them to be effective, so the safeguards relied upon are untested and may be unenforceable in practice.

Art. 47 Binding corporate rules

WHAT THE ARTICLE REQUIRES

Binding corporate rules must be approved by the competent supervisory authority, be legally binding on and enforced by every member of the group including employees, expressly confer enforceable rights on data subjects, and specify the group structure, transfers concerned, their binding nature, the application of the data protection principles, data subject rights, acceptance of liability by the Union-established member, how information is provided to data subjects, the tasks of the data protection officer, complaint procedures, compliance verification mechanisms, and training.

WHY IT EXISTS

Binding corporate rules suit intra-group transfers but require approval and carry substantial ongoing obligations, including liability acceptance by the Union-established member. Organizations sometimes describe internal policies as binding corporate rules without approval, which provides no valid transfer basis.

HOW TO AUDIT IT

1. Verify any binding corporate rules relied upon are actually approved by the competent authority.
2. Check they cover the entities and transfers to which they are applied.
3. Confirm the compliance verification and complaint mechanisms operate.

EVIDENCE TO COLLECT

- Approval evidence from the competent authority
- Scope of entities and transfers covered
- Verification and complaint mechanism records

HOW TO DOCUMENT IT

Record whether rules described as binding corporate rules have actually been approved, since unapproved internal policies provide no transfer basis whatever their content.

EXECUTIVE SUMMARY TREATMENT

Suggested language: intra-group transfers rely on internal policies described as binding corporate rules that have never been submitted for approval, so those transfers have no valid basis.

Art. 48 Transfers or disclosures not authorised by Union law**WHAT THE ARTICLE REQUIRES**

Any judgment of a court or tribunal and any decision of an administrative authority of a third country requiring a controller or processor to transfer or disclose personal data may only be recognised or enforceable if based on an international agreement such as a mutual legal assistance treaty in force between the requesting third country and the Union or a Member State, without prejudice to other grounds for transfer under Chapter V.

WHY IT EXISTS

This addresses the conflict where a third-country authority demands data directly. Complying with such a demand without an international agreement basis is itself a transfer breach, and organizations with group entities in third countries can face genuinely conflicting legal obligations that need to be identified in advance rather than during a demand.

HOW TO AUDIT IT

1. Establish whether the organization is exposed to third-country authority demands.
2. Check whether a process exists for assessing such demands against Article 48 before responding.
3. Examine any actual demands received and how they were handled.

EVIDENCE TO COLLECT

- Process for handling third-country authority demands
- Records of demands received and responses
- Conflict-of-laws analysis

HOW TO DOCUMENT IT

Record whether a process exists to assess such demands before responding, since compliance under time pressure without analysis is where the breach occurs.

EXECUTIVE SUMMARY TREATMENT

Suggested language: no process exists for assessing third-country authority demands for personal data, so such demands would likely be met without the Article 48 analysis the Regulation requires.

Art. 49 Derogations for specific situations

WHAT THE ARTICLE REQUIRES

In the absence of adequacy or appropriate safeguards, a transfer may take place only if the data subject has explicitly consented having been informed of the risks, the transfer is necessary for a contract with or in the interest of the data subject, for important reasons of public interest, for legal claims, to protect vital interests where the data subject is incapable of consent, or is made from a public register. A residual derogation permits non-repetitive transfers of a limited number of data subjects where necessary for compelling legitimate interests not overridden by the data subject's interests, subject to assessment, suitable safeguards, and notification of the supervisory authority and the data subject.

WHY IT EXISTS

These are exceptions for specific situations, not a routine transfer mechanism. The derogations are narrow and most are unsuited to systematic transfers: contractual necessity covers the occasional transfer required to deliver a service, not a standing data flow. Organizations relying on derogations for routine operations have misapplied them.

HOW TO AUDIT IT

1. Identify transfers relying on derogations and assess whether use is occasional rather than systematic.
2. For consent-based transfers, verify explicit consent with information about the risks.
3. Check contractual necessity claims are genuine necessity rather than convenience.
4. Where the residual derogation is used, verify the assessment, safeguards, and notifications.

EVIDENCE TO COLLECT

- Derogation reliance per transfer
- Explicit consent records with risk disclosure
- Necessity analysis

HOW TO DOCUMENT IT

Record transfers where a derogation supports a routine, systematic flow, since the derogations are designed for specific situations and cannot bear that weight.

EXECUTIVE SUMMARY TREATMENT

Suggested language: routine, systematic transfers rely on the contractual necessity derogation, which is available only for occasional transfers, so those flows have no valid Chapter V basis.

CHAPTER 7

Remedies, Liability, and Penalties

Four entries covering Articles 77 to 84. Blue throughout, because these provisions create remedies and set penalties rather than imposing obligations that attract fines of their own.

Article 83 is the one to read carefully, because it supplies the tiering this guide's colour coding uses and because its factor list is directly actionable. Several factors sit within the organization's control at the moment of an incident: self-reporting, cooperation, and demonstrable mitigation all reduce exposure, which makes operational readiness to do those things a risk control rather than merely good practice.

Assessing the organization against the Article 83(2) factors is also the most effective way to convert a set of abstract compliance findings into a statement executives understand. Article 82 is worth noting alongside it: non-material damage is compensable, and liability is joint and several, so an organization can bear the entire damage caused partly by a processor and will want contractual recourse it often does not have.

Quick reference: Remedies and Penalties

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
Art. 77-79	Complaints and judicial remedies	Complaint records with themes
Art. 82	Right to compensation and liability	Liability and indemnity provisions in contracts
Art. 83	General conditions for imposing administrative fines	Evidence supporting mitigating factors
Art. 84	Penalties under Member State law	National penalty regime analysis per Member State

Art. 77-79 Complaints and judicial remedies**WHAT THE ARTICLE REQUIRES**

Every data subject has the right to lodge a complaint with a supervisory authority, in particular in the Member State of their residence, place of work, or place of the alleged infringement, and the authority must inform the complainant of progress and outcome. Data subjects also have the right to an effective judicial remedy against a supervisory authority's legally binding decision or failure to act, and against a controller or processor where they consider their rights have been infringed.

WHY IT EXISTS

These provisions matter to a controller for two practical reasons: complaints are a primary trigger for supervisory attention, and the complaint pattern is diagnostic. A cluster of complaints on a single process indicates a systemic issue that internal monitoring has failed to surface.

HOW TO AUDIT IT

1. Verify data subjects are informed of the right to complain, as Articles 13 and 14 require.
2. Examine complaint volumes and themes for patterns indicating systemic issues.
3. Check whether complaints received directly are analysed rather than only resolved individually.
4. Confirm any supervisory authority complaints are tracked and their outcomes acted upon.

EVIDENCE TO COLLECT

- Complaint records with themes
- Supervisory authority correspondence
- Root cause analysis of complaint patterns

HOW TO DOCUMENT IT

Record whether complaints are analysed for pattern as well as resolved individually, since a recurring complaint theme is direct evidence of a systemic failure the organization has chosen not to address.

EXECUTIVE SUMMARY TREATMENT

Suggested language: complaints are resolved individually with no pattern analysis, and a recurring theme across a stated number of complaints indicates a systemic failure that has persisted unaddressed.

Art. 82 Right to compensation and liability

WHAT THE ARTICLE REQUIRES

Any person who has suffered material or non-material damage as a result of an infringement has the right to receive compensation from the controller or processor. A controller is liable for damage caused by processing which infringes the Regulation. A processor is liable only where it has not complied with obligations specifically directed to processors or has acted outside or contrary to lawful instructions. Controllers or processors are exempt if they prove they are not in any way responsible for the event giving rise to the damage. Where more than one is involved, each may be held liable for the entire damage, with rights of recourse between them.

WHY IT EXISTS

Non-material damage is compensable, which extends liability well beyond financial loss to distress and loss of control over personal data. The joint and several structure means an organization can be liable for the entire damage even where another party contributed, making the indemnity and recourse provisions in processor contracts commercially significant.

HOW TO AUDIT IT

1. Assess whether contractual allocation of liability with processors reflects the Article 82 structure.
2. Check whether the organization has assessed its exposure to non-material damage claims.
3. Verify recourse rights are secured in processor and joint controller arrangements.

EVIDENCE TO COLLECT

- Liability and indemnity provisions in contracts
- Recourse arrangements
- Claims history

HOW TO DOCUMENT IT

Record whether processor contracts secure recourse, since joint and several liability means the organization may bear damage caused by a processor with no contractual route to recover it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: processor contracts contain no indemnity or recourse provisions, so the organization bears joint and several liability for damage caused by its processors with no contractual means of recovery.

Art. 83 General conditions for imposing administrative fines

WHAT THE ARTICLE REQUIRES

Supervisory authorities must ensure fines are effective, proportionate, and dissuasive, having regard to the nature, gravity, and duration of the infringement, its intentional or negligent character, actions taken to mitigate damage, degree of responsibility having regard to Articles 25 and 32, relevant previous infringements, degree of cooperation, categories of data affected, how the infringement became known, compliance with previously ordered measures, adherence to codes or certification, and other aggravating or mitigating factors. Two tiers apply: up to EUR 10 million or 2% turnover for the infringements listed in Article 83(4), and up to EUR 20 million or 4% turnover for the infringements listed in Article 83(5), whichever is higher in each case.

WHY IT EXISTS

This article supplies the tiering that structures this guide's colour coding, and its factor list is directly actionable: several factors are within the organization's control at the time of an incident. Self-reporting, cooperation, and demonstrable mitigation all reduce exposure, which makes the operational readiness to do those things a risk control in its own right.

HOW TO AUDIT IT

1. Assess the organization's position against the mitigating and aggravating factors.
2. Check whether data protection by design and security measures are demonstrable, since Article 83(2)(d) refers to them explicitly.
3. Verify the organization is positioned to self-report and cooperate promptly.
4. Examine whether previous infringements or supervisory orders have been fully addressed.

EVIDENCE TO COLLECT

- Evidence supporting mitigating factors
- Records of previous infringements and remediation
- Incident self-reporting capability

HOW TO DOCUMENT IT

Assess the organization against the Article 83(2) factors directly, since this converts abstract compliance findings into a concrete statement about exposure that executives understand.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's position against the Article 83(2) factors is unfavourable, with no demonstrable data protection by design measures, unaddressed findings from a previous supervisory engagement, and no capability to self-report promptly.

Art. 84 Penalties under Member State law

WHAT THE ARTICLE REQUIRES

Member States must lay down rules on other penalties applicable to infringements, in particular for infringements not subject to administrative fines under Article 83, and take all measures necessary to ensure they are implemented. Such penalties must be effective, proportionate, and dissuasive.

WHY IT EXISTS

National penalty regimes sit alongside the Article 83 fines and vary by Member State, and in some they include criminal liability for specified conduct. An organization operating in several Member States faces a different penalty landscape in each, which the Regulation's harmonisation does not eliminate.

HOW TO AUDIT IT

1. Identify the Member States in which the organization operates and the applicable national penalty regimes.
2. Check whether any national provisions create criminal or personal liability.
3. Verify these are reflected in the organization's risk assessment.

EVIDENCE TO COLLECT

- National penalty regime analysis per Member State
- Risk assessment reflecting national provisions

HOW TO DOCUMENT IT

Record whether national penalty regimes were analysed, since organizations focused on the Article 83 tiers frequently overlook national provisions including personal liability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's data protection risk assessment addresses Article 83 fines only, with no analysis of national penalty regimes in the Member States where it operates, some of which provide for personal liability.

CHAPTER 8

Specific Processing Situations

Four entries from Chapter IX, where the Regulation defers to Member State law. These are 4

The practical significance is that harmonisation stops here. National rules vary materially, so an approach lawful in one Member State may not be lawful in another, and an organization operating across several faces a different landscape in each.

Article 88 is the one that applies to almost every organization, because every employer processes employee data. The recurring finding is reliance on consent: the imbalance of power between employer and employee means consent is rarely freely given, so processing that rests on it frequently has no valid basis at all. Workplace monitoring is named explicitly in the article, national rules on it are often more restrictive than the Regulation's baseline, and works councils have a statutory role in several Member States.

Quick reference: Specific Situations

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
Art. 85^{4%}	Processing and freedom of expression and information	Identification of expression-related processing
Art. 87^{4%}	Processing of national identification numbers	National identifier processing inventory
Art. 88^{4%}	Processing in the context of employment	Employee processing inventory with legal bases
Art. 89^{4%}	Safeguards for archiving, research, and statistical purposes	Article 89 processing inventory

Art. 85 Processing and freedom of expression and information**WHAT THE ARTICLE REQUIRES**

Member States must reconcile by law the right to the protection of personal data with the right to freedom of expression and information, including processing for journalistic purposes and the purposes of academic, artistic, or literary expression. For such processing, Member States must provide exemptions or derogations from most of the Regulation where necessary to reconcile the two rights.

WHY IT EXISTS

This is a Member State law matter rather than a direct controller obligation, but it defines the boundary where data protection yields to expression. Organizations engaged in publishing, research dissemination, or archival activity may fall within national derogations, and the scope varies materially between Member States.

HOW TO AUDIT IT

1. Establish whether any processing falls within journalistic, academic, artistic, or literary expression.
2. Identify the applicable national derogation and its scope.
3. Verify reliance on any derogation is documented and correctly scoped.

EVIDENCE TO COLLECT

- Identification of expression-related processing
- National derogation analysis

HOW TO DOCUMENT IT

Record the national derogation relied upon and its scope, since these vary substantially between Member States and a derogation available in one may not exist in another.

EXECUTIVE SUMMARY TREATMENT

Suggested language: processing is treated as exempt on freedom of expression grounds without identifying the national law derogation relied upon or confirming its scope covers the activity.

Art. 87 Processing of national identification numbers

WHAT THE ARTICLE REQUIRES

Member States may further determine the specific conditions for the processing of a national identification number or any other identifier of general application. Where used, such an identifier must be processed only with appropriate safeguards for the rights and freedoms of the data subject.

WHY IT EXISTS

National identification numbers are high-risk identifiers because they enable linkage across otherwise separate datasets and are a primary vector for identity fraud. National conditions vary considerably, and processing one lawfully in one Member State does not establish lawfulness in another.

HOW TO AUDIT IT

1. Identify processing of national identification numbers.
2. Verify the applicable national conditions are identified and met.
3. Check appropriate safeguards are applied to these identifiers specifically.
4. Assess whether the identifier is necessary or used as a convenient key.

EVIDENCE TO COLLECT

- National identifier processing inventory
- National condition analysis per Member State
- Safeguards specific to these identifiers

HOW TO DOCUMENT IT

Record whether national identifiers are used as internal database keys, since this propagates a high-risk identifier across systems where it is rarely necessary.

EXECUTIVE SUMMARY TREATMENT

Suggested language: national identification numbers are used as internal record keys across systems, propagating a high-risk identifier well beyond the processing that requires it and without the national conditions being assessed.

Art. 88 Processing in the context of employment

WHAT THE ARTICLE REQUIRES

Member States may provide by law or collective agreement more specific rules to ensure the protection of rights and freedoms in respect of the processing of employees' personal data in the employment context, including for recruitment, performance of the contract, management, planning, equality and diversity, health and safety, and the exercise of employment rights. Such rules must include suitable and specific measures to safeguard human dignity, legitimate interests, and fundamental rights, with particular regard to transparency, transfers within a group, and monitoring systems at the workplace.

WHY IT EXISTS

Employment is the context where consent is least likely to be valid, because the imbalance of power between employer and employee means consent is rarely freely given. Workplace monitoring is named explicitly, and national rules in this area are often more restrictive than the Regulation's baseline, particularly where works councils have a statutory role.

HOW TO AUDIT IT

1. Identify employee data processing and the legal basis relied upon for each.
2. Check that consent is not relied upon where the power imbalance makes it invalid.
3. Examine workplace monitoring against national rules and proportionality.
4. Verify applicable collective agreements and works council requirements are met.

EVIDENCE TO COLLECT

- Employee processing inventory with legal bases
- Monitoring assessments including proportionality
- National employment rules and collective agreements

HOW TO DOCUMENT IT

Record employee processing relying on consent, since the power imbalance makes consent presumptively invalid in this context and processing then has no basis at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: employee monitoring relies on consent obtained through the employment contract, which is not freely given given the imbalance of power, so the monitoring has no valid legal basis.

Art. 89 Safeguards for archiving, research, and statistical purposes

WHAT THE ARTICLE REQUIRES

Processing for archiving purposes in the public interest, scientific or historical research purposes, or statistical purposes must be subject to appropriate safeguards for the rights and freedoms of the data subject, ensuring technical and organisational measures are in place in particular to ensure respect for data minimisation. Those measures may include pseudonymisation where the purposes can be fulfilled that way, and where they can be fulfilled by further processing which does not permit identification, they must be fulfilled in that manner. Union or Member State law may provide derogations from specified data subject rights subject to those safeguards.

WHY IT EXISTS

Article 89 is what makes research and archiving workable, but the safeguards are a precondition rather than an afterthought: the derogations are available only where the safeguards are in place. The requirement to fulfil purposes without identification where possible is a strong minimisation obligation that is frequently overlooked.

HOW TO AUDIT IT

1. Identify processing relying on Article 89 and the derogations claimed.
2. Verify the required safeguards are actually implemented, since they condition the derogations.
3. Check whether purposes could be fulfilled without identification, and whether that route was taken.
4. Confirm the applicable national law derogation is identified.

EVIDENCE TO COLLECT

- Article 89 processing inventory
- Safeguards implemented including pseudonymisation
- Assessment of whether identification is necessary

HOW TO DOCUMENT IT

Record whether the safeguards preceded reliance on the derogations, since derogations claimed without the conditioning safeguards are simply unmet obligations.

EXECUTIVE SUMMARY TREATMENT

Suggested language: research processing relies on Article 89 derogations from data subject rights without the pseudonymisation and minimisation safeguards that condition those derogations, so the rights were restricted without a valid basis.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Accountability

The Article 5(2) principle that the controller is not only responsible for compliance but must be able to demonstrate it. Converts every other principle into an evidence requirement, and reverses the usual burden of proof.

Adequacy decision

A Commission decision that a third country, territory, sector, or international organisation ensures an adequate level of protection, permitting transfers without further authorisation. Subject to review, and capable of being suspended or invalidated.

Anonymisation

Rendering data such that the individual is no longer identifiable by any means reasonably likely to be used. Genuinely anonymous data falls outside the Regulation entirely, which is why claims of anonymisation warrant testing for reversibility through linkage.

BCR

Binding corporate rules. A transfer mechanism for intra-group transfers, requiring approval by the competent supervisory authority. Internal policies not so approved provide no transfer basis.

Controller

The party determining the purposes and means of processing. Determined by factual reality rather than by contractual label.

Data subject

The identified or identifiable natural person to whom personal data relates.

DPIA

Data protection impact assessment. Required under Article 35 where processing is likely to result in high risk, and required prior to processing. A DPIA completed after deployment has failed its purpose regardless of its content.

DPO

Data protection officer. Mandatory in the circumstances set out in Article 37. Must be independent, free of conflicts, and reporting to the highest management level.

Establishment

The basis for territorial scope under Article 3(1). Implies effective and real exercise of activity through stable arrangements; legal form is not decisive.

Joint controllers

Two or more controllers jointly determining purposes and means. Arises from factual joint determination, not from an agreement to be joint controllers. Data subjects may exercise rights against either, regardless of the internal allocation.

Legitimate interests

The Article 6(1)(f) basis, requiring a balancing test against the data subject's interests, rights, and freedoms. Unavailable to public authorities in the performance of their tasks. Triggers the Article 21 right to object.

Non-material damage

Damage other than financial loss, including distress and loss of control over personal data. Compensable under Article 82, which extends liability well beyond quantifiable loss.

Personal data

Any information relating to an identified or identifiable natural person. Identifiability is relative and assessed against all means reasonably likely to be used, by the controller or by anyone else.

Personal data breach

A breach of security leading to accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. Includes accidental loss and destruction, not only unauthorised access.

Processor

A party processing personal data on behalf of a controller. Processing must be governed by an Article 28 contract containing the specified terms.

Profiling

Automated processing to evaluate personal aspects of a natural person, in particular to analyse or predict performance, economic situation, health, preferences, interests, reliability, behaviour, location, or movements.

Pseudonymisation

Processing such that data can no longer be attributed to a data subject without additional information kept separately and subject to safeguards. Pseudonymised data remains personal data and remains fully in scope.

Purpose limitation

The Article 5(1)(b) principle that data collected for specified, explicit, and legitimate purposes must not be further processed incompatibly. Article 6(4) supplies the compatibility test.

SCCs

Standard contractual clauses. The most used Article 46 transfer mechanism. Executing them is necessary but not sufficient: a transfer impact assessment of the destination country is also required, with supplementary measures where it identifies risk.

Special category data

Data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and genetic, biometric (for identification), health, sex life, or sexual orientation data. Requires an Article 9(2) condition in addition to an Article 6 basis. Data revealing such a category, including by inference, is itself special category data.

Supervisory authority

The independent public authority responsible for monitoring application of the Regulation in a Member State.

Third country

Any country outside the European Economic Area, for the purposes of Chapter V.

Transfer impact assessment

The assessment of whether the law and practice of a destination country prevent an Article 46 mechanism being effective. Not named as such in the Regulation but required in substance for reliance on standard contractual clauses.

Workpaper

The assessor's record of what was tested, how, what was found, and what was concluded. Written so a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Accountability, 8, 72
- Accuracy, 5
- Adequacy decision, 72
- Anonymisation, 72
- Automated individual decision-making, including profiling, 33

- BCR, 72
- Binding corporate rules, 59

- Certification and certification bodies, 54
- Child's consent for information society services, 18
- Codes of conduct and monitoring, 53
- Communication of a personal data breach to the data subject, 47
- Complaints and judicial remedies, 63
- Conditions for consent, 17
- Controller, 72
- Controller and processor roles, 13
- Cooperation with the supervisory authority, 44

- Data minimisation, 4
- Data protection by design and by default, 38
- Data protection impact assessment, 48
- Data subject, 72
- Derogations for specific situations, 61
- Designation of the data protection officer, 50
- DPIA, 72
- DPO, 72

- Establishment, 72

- Further processing and the compatibility test, 16
- General conditions for imposing administrative fines, 65
- General principle for transfers, 56

- Information where data is collected from the data subject, 24
- Information where data is not obtained from the data subject, 25

- Integrity and confidentiality, 7

- Joint controllers, 39, 72

- Key definitions: personal data, processing, pseudonymisation, 12

- Lawfulness of processing: the six legal bases, 15
- Lawfulness, fairness and transparency, 2
- Legitimate interests, 73

- Material scope: what processing is covered, 10

- Non-material damage, 73
- Notification obligation regarding rectification, erasure, or restriction, 30
- Notification of a personal data breach to the supervisory authority, 46

- Penalties under Member State law, 66
- Personal data, 73
- Personal data breach, 73
- Personal data relating to criminal convictions and offences, 20
- Position of the data protection officer, 51
- Prior consultation with the supervisory authority, 49
- Processing and freedom of expression and information, 68
- Processing in the context of employment, 70
- Processing not requiring identification, 21
- Processing of national identification numbers, 69
- Processing under the authority of the controller or processor, 42
- Processor, 73
- Processor obligations and the processing contract, 41
- Profiling, 73
- Pseudonymisation, 73
- Purpose limitation, 3, 73

- Records of processing activities, 43

- Representatives of controllers or processors not established in the Union, [40](#)
- Responsibility of the controller, [37](#)
- Restrictions under Union or Member State law, [34](#)
- Right of access, [26](#)
- Right to compensation and liability, [64](#)
- Right to data portability, [31](#)
- Right to erasure, [28](#)
- Right to object, [32](#)
- Right to rectification, [27](#)
- Right to restriction of processing, [29](#)
- Safeguards for archiving, research, and statistical purposes, [71](#)
- SCCs, [73](#)
- Security of processing, [45](#)
- Special categories of personal data, [19](#)
- Special category data, [73](#)
- Storage limitation, [6](#)
- Supervisory authority, [73](#)
- Tasks of the data protection officer, [52](#)
- Territorial scope: establishment and targeting, [11](#)
- Third country, [73](#)
- Transfer impact assessment, [74](#)
- Transfers on the basis of an adequacy decision, [57](#)
- Transfers or disclosures not authorised by Union law, [60](#)
- Transfers subject to appropriate safeguards, [58](#)
- Transparent information and modalities for exercising rights, [23](#)
- Workpaper, [74](#)